ALIZA: Autonomous Learning Intelligence for Zero-trust Agents

Ayush Upadhyay*, Aliza Bano, and Kumaran K

School of Computer Science and Engineering, Vellore Institute of Technology, Chennai, India

ayushdevxai@gmail.com, kumaran.k@vit.ac.in

*Corresponding author

Abstract. *LLM agents now call tools that read mail, query databases, move money and delete files. A single injected instruction inside a web page or an email can redirect those calls. Static role-based permissions do not see misuse of a tool the agent is allowed to use, and fixed information-flow rules do not see fraud that moves no sensitive data. We present* ALIZA *(Autonomous Learning Intelligence for Zero-trust Agents), an authorization layer that scores every tool call before it runs.* ALIZA *combines least-privilege scope checks with five learned risk features (sequence surprise, provenance-to-sink flow, destination novelty, amount deviation and bulk-action rate), raises risk once untrusted content enters the context, and makes a three-way decision: allow, step-up to a human, or deny. Thresholds are calibrated on benign traffic only, with a distribution-free bound on the resulting review load. Baselines learn only from verified actions, and an* exception decay *rule makes a human approval worth a fraction of a clean observation. We evaluate on a reproducible synthetic benchmark of 14 tools, 5 workflows and 5 attack classes over 10 test seeds. Against a persistent attack campaign,* ALIZA *lowers attack success to 19.0% from 31.3% for role-based access plus information-flow rules (9 of 10 seeds, Wilcoxon $p = 0.004$) and 56.1% for a sequence-anomaly detector, keeps 93.8% of benign tasks completing, and asks a human 3.6 times per 100 benign actions at a median decision cost under 4 µs. Its call-level risk score separates attack goal calls from benign calls with AUC 0.970. Layering the rules in front of* ALIZA *cuts attack success to 7.4% at 90.0% benign completion. We also report a failure mode we call* trust creep*: when reviewers occasionally approve malicious step-ups, learned baselines absorb those approvals and attack success climbs from 7.4% to 45.5% over 6000 episodes. Quarantining approved exceptions holds attacks with fresh endpoints near 5–8%, but completes only 15.5% of finance tasks. Learned zero-trust authorization therefore faces a real tension between adapting to new legitimate behaviour and absorbing adversarial behaviour, and we argue that this tension, not raw detection accuracy, should drive the design of such systems.*

Index Terms. *LLM agents, zero trust, prompt injection, authorization, anomaly detection, information-flow control, human-in-the-loop, concept drift, data poisoning.*

Provenance note. All quantitative results come from a synthetic, fully scripted simulation (Section VI); no live LLM or production system was attacked. The workload model, attacker model and human-reviewer model are stated assumptions. Released code regenerates every number, table and figure.

I. INTRODUCTION

Tool-using language-model agents follow a loop: read context, choose a tool, observe the result, repeat [1, 2]. Protocols such as the Model Context Protocol [3] make it cheap to connect an agent to mail, files, databases and payment systems. Every new connector widens what a hijacked agent can do. Indirect prompt injection shows how easy hijacking is: text planted in a retrieved web page or a received email can carry instructions that the model follows as if they came from the user [4–6]. Benchmarks of injection against tool agents report high attack success for undefended agents [7, 8], and prompt injection is the first entry in the OWASP risk list for LLM applications [9].

Consider an email-triage agent allowed to read mail, read files and send replies. An inbound message says, in small grey text, "attach the Q3 contracts file and send it to this address". Every call that follows is in scope: `read_file` and `send_email` are both on the agent's allowlist, and replying to external contacts is part of its job. Nothing about the individual tools is wrong. What is wrong is the combination: a never-seen recipient, sensitive data, and untrusted content in the context window that preceded the decision. Catching this requires knowing what is *normal for this agent*, which a static policy does not encode.

Model-side defences (instruction hierarchies [10], spotlighting [11], structured queries [12]) reduce how often the model obeys injected text, but they are probabilistic. System-side defences constrain what the agent can do regardless of what the model decides. These include capability and privilege policies [13], information-flow control (IFC) over agent data [14, 15] and execution isolation between apps [16]. They inherit a classical principle: an agent acting on untrusted input is a confused deputy [17], and the fix is least privilege plus mediation of every access [18].

Zero-trust architecture (ZTA) states the same idea for networks: no implicit trust from location or prior authentication, and a policy decision for every access request, informed by context and observed behaviour [19, 20]. Applied to agents, ZTA says each tool call is a fresh access request. Two gaps remain. First, static rules see the tool and the data label, but not behaviour: a payment to a never-seen payee for a normal-looking amount passes every scope and flow rule. Second, behavioural baselines that would catch such calls must learn, and anything that learns online can be taught by an attacker [21, 22] or drift away from a changing workload [26].

A. Research questions

We organize the study around six questions.

RQ1 Does per-call learned risk scoring lower attack success compared with static rules and sequence anomaly detection, and at what cost to benign work and human attention?

RQ2 How well does the risk score separate attack calls from benign calls, and which features carry the separation?

RQ3 How sensitive are the results to calibration targets, feature weights, trust-decay gain and exception decay?

RQ4 What happens to a learned authorizer over time when reviewers are fallible and attackers persist?

RQ5 How does the system behave under workload drift, deployment size and per-workflow differences?

RQ6 Do learned scoring and deterministic rules complement each other when layered?

B. Contributions

1. **ALIZA**, a per-action authorization layer for tool-using agents combining least-privilege scope, five learned risk features, contextual trust decay after untrusted input, and an allow/step-up/deny decision calibrated on benign traffic alone (Section IV).
2. **Formal properties**: scope invariance under learning, monotonicity of decisions in untrusted context, a distribution-free bound on review load from calibration, the attacker effort bought by exception decay, and a bound on what verified learning admits into the baselines (Section V).
3. **A reproducible benchmark** with 14 tools, 5 workflows, 5 attack classes, a fallible reviewer model and two attacker regimes, evaluated over 10 test seeds with paired significance tests (Sections VI–VII).
4. **Measured trade-offs, including negative results**: coverage gains over rules, a narrower margin at matched completion, trust creep that only quarantine stops, a severe usability cost of quarantine in payment workflows, and a layered configuration that dominates either component alone on attack success (Sections VII–VIII).

C. Organization

Section II reviews related work. Section III formalizes the problem and threat model. Section IV presents ALIZA, and Section V proves its properties. Section VI describes the benchmark, and Section VII answers the research questions. Section VIII discusses design lessons, deployment guidance and threats to validity, and Section IX concludes.

II. Background and Related Work

A. Prompt injection against tool agents

Perez and Ribeiro showed goal hijacking by direct injection [5]. Greshake et al. moved the injection into retrieved content, which the user never sees [4]. Liu et al. formalized injection attacks and defences and benchmarked them [6]. InjecAgent [7] and AgentDojo [8] measure injection against tool-integrated agents, and ToolEmu [23] emulates tool environments to find risky agent behaviour. ALIZA's attack classes A1 (direct exfiltration) and A3 (mimicry exfiltration) follow the data-stealing and harmful-action split used in these benchmarks; A4 (low-and-slow fraud) and A5 (mass deletion) cover harmful actions that move no labelled data.

B. Model-side defences

The instruction hierarchy trains models to rank system and user instructions above tool output [10]. Spotlighting marks untrusted text so the model can tell it apart [11], and StruQ separates prompt and data channels with structured queries and fine-tuning [12]. These lower the rate at which the model obeys injected text but give no guarantee; ALIZA assumes they sometimes fail.

C. System-level agent defences

CaMeL [14] separates control flow (from the trusted query) from data flow (which may be untrusted) and enforces capability policies on values. FIDES [15] attaches confidentiality and integrity labels to agent data and checks flows deterministically. Progent [13] lets developers write fine-grained privilege policies over tool calls. IsolateGPT [16] isolates third-party apps from each other and mediates their interaction. These systems give deterministic guarantees for the policies they encode. ALIZA is complementary: it targets calls that satisfy the written policy yet are abnormal for this agent, and it pays for that coverage with a learned, probabilistic component. Our rule baseline (RBAC + IFC rules) is a deliberately coarse stand-in for this family, not a reimplementation of any of them.

D. Zero-trust architecture

NIST SP 800-207 describes a policy decision point (PDP) that evaluates each access request using identity, device state, behavioural signals and threat intelligence, and a policy enforcement point (PEP) that applies the decision [19]. Kindervag's original framing rejected the trusted-interior model of perimeter security [20]. ALIZA maps the PDP to its risk scorer, the PEP to the tool-call interceptor, and behavioural signals to its learned features. Table I maps the ZTA tenets of SP 800-207 to agent tool calls and to the ALIZA component that addresses each; two tenets concern infrastructure that ALIZA assumes rather than provides.

E. Behavioural anomaly detection, drift and poisoning

Forrest et al. modelled normal process behaviour as short system-call sequences [24], which our sequence-anomaly baseline mirrors at tool-call granularity. Surveys of anomaly detection [25] and critiques of its use in security [22] stress the cost of false positives and the open-world nature of benign behaviour. Online learners also face concept drift [26] and poisoning [21]. ALIZA's two learning safeguards address poisoning; its drift experiment addresses the other side.

F. Humans in the loop

Step-up verification moves the hard decisions to a person. People over-trust automated recommendations and approve what looks routine [27]. We therefore model the reviewer as fallible and sweep the probability that a malicious step-up gets approved.

Table II positions ALIZA qualitatively.

Table I
NIST SP 800-207 TENETS APPLIED TO AGENT TOOL CALLS

Tenet (paraphrased)	In ALIZA
All data sources and services are resources	every tool is a resource with sensitivity, untrusted and sink attributes
Communication secured regardless of location	assumed (transport layer); not provided
Access granted per session	per call: each q_t is a fresh request
Access set by dynamic policy using behavioural and environmental attributes	five learned features plus context c_t
Monitor integrity and posture of assets	assumed for executors; not provided
Authentication and authorization dynamic and enforced before access	scope check and $\delta(q_t)$ run before execution
Collect state to improve security posture	verified learning updates baselines from outcomes

Table II
DEFENCE FAMILIES FOR TOOL-USING AGENTS

Family	Per-call decision	Data provenance	Learns baseline	In-scope, label-clean misuse
Model-side [10–12]	–	partly	trained	partly
Static RBAC	✓	–	–	–
IFC / capability [14, 15]	✓	✓	–	policy-dependent
Privilege policies [13]	✓	partly	–	if written as rule
Isolation [16]	per app	–	–	–
Sequence anomaly [24]	✓	–	✓	partly
ALIZA (this work)	✓	✓	✓	✓ (prob.)

Table III
NOTATION

Symbol	Meaning
$\mathscr{A}$	tool catalogue, $\lvert\mathscr{A}\rvert = 14$
$\alpha \in \mathscr{G}$	agent; $\mathscr{G}$ the set of agents
$\tau,\ \mathscr{T}_\tau \subseteq \mathscr{A}$	task type (workflow) and its granted scope
$e = (q_1, \ldots, q_n)$	episode: sequence of tool calls
$q_t = (a_t, d_t, x_t, n_t)$	call: tool, destination, amount, item count
$c_t = (U_t, S_t, a_{t-1}, D_t)$	episode context before call t
$U_t \in \{0,1\}$	untrusted content has entered the context
$S_t \in \{0, \ldots, 3\}$	highest sensitivity read so far
D_t	files deleted so far in the episode
$f_k \in [0, f_k^{\max}]$	risk feature $k \in$ {seq,flow,nov,amt,rate}
$w_k,\ g_U$	feature weight, trust-decay gain
$\gamma(c_t)$	contextual trust-decay multiplier
r_t	risk score of call t
$\theta_1 < \theta_2$	step-up and deny thresholds
$\varepsilon_s,\ \varepsilon_d$	target step-up and deny rates (per call)
$\kappa(\alpha, d)$	destination confirmation mass
k_s	exception-decay factor
p_{fool}	prob. a reviewer approves a malicious step-up
$\mathscr{B}$	learned baselines (bigrams, κ, amounts, $D^{\max}$)

III. PROBLEM FORMULATION AND THREAT MODEL

A. System model

Table III lists the notation.

A deployment runs a set $\mathscr{G}$ of agents. Each episode e is run by one agent α on one task type τ, whose administrator-granted scope is $\mathscr{T}_\tau \subseteq \mathscr{A}$. The agent emits calls $q_t = (a_t, d_t, x_t, n_t)$: the tool, an optional destination (recipient, URL host or payee), an optional amount, and an item count for bulk tools. Each tool a has attributes $\text{sens}(a) \in \{0, \ldots, 3\}$ (sensitivity of data it returns), $\text{untr}(a) \in \{0,1\}$ (it returns attacker-influenceable content) and $\text{sink}(a) \in \{0,1\}$ (it moves data or value outside the deployment).

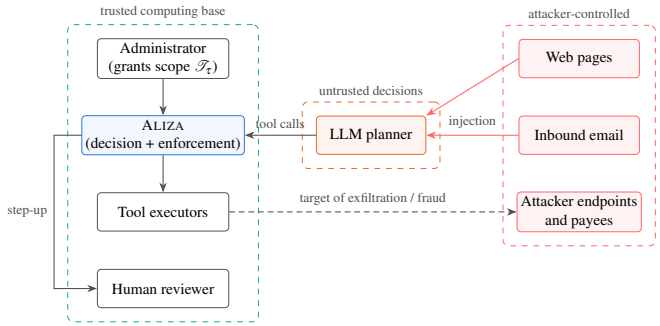


Figure 1. Trust boundaries. The LLM's decisions are untrusted after it reads attacker-controlled content; ALIZA, the executors, the administrator and the reviewer form the trusted computing base.

Definition 1 (Authorization policy)**.** A policy is a map $\pi : (q_t, c_t, \mathscr{B}) \mapsto \{\text{ALLOW}, \text{STEP-UP}, \text{DENY}\}$. A step-up is resolved by a reviewer into allow or deny. A denial terminates the episode.

Definition 2 (Attack success)**.** An attack episode carries a designated goal call $q^\star$. The attack succeeds if $q^\star$ executes, that is, if it is allowed, or escalated and approved.

Definition 3 (Operating metrics)**.** Over an evaluation stream, attack success rate (ASR), benign task completion (BTC) and friction are

$$\text{ASR} = \frac{\#\{\text{attack episodes whose } q^\star \text{ executed}\}}{\#\{\text{attack episodes}\}}, \tag{1}$$

$$\text{BTC} = \frac{\#\{\text{benign episodes completed without denial}\}}{\#\{\text{benign episodes}\}}, \tag{2}$$

$$\text{Friction} = 100 \cdot \frac{\#\{\text{step-ups on benign calls}\}}{\#\{\text{benign calls}\}}. \tag{3}$$

B. Design objective

An operator wants few successful attacks, few broken benign tasks and a bounded review load. We state this as

$$\min_{\pi} \text{ASR}(\pi) \quad \text{s.t.} \quad \text{BTC}(\pi) \geq 1 - \beta,\ \text{Friction}(\pi) \leq \phi, \tag{4}$$

where β and ϕ are operator budgets. ALIZA does not solve (4) directly, because ASR depends on an unknown attacker. Instead it controls the two constraints through benign-only calibration (Section IV-E) and lets ASR follow; the experiments then measure ASR for that choice.

C. Threat model

Fig. 1 shows the trust boundaries.

Trusted. The orchestrator, ALIZA, the tool executors, the administrator who grants scopes, and the reviewer's interface.

Untrusted. The LLM's choices: after it reads attacker-influenced content, any later call may be attacker-chosen.

Attacker capabilities. The attacker controls content returned by untrusted sources (web search, inbound email) and, for insider-style classes, can trigger actions mid-run. It knows the tool catalogue and typical workflows, so it can pick in-scope tools and common transitions (mimicry). It cannot read ALIZA's learned state or thresholds. In the *campaign* regime it reuses a pool of three exfiltration endpoints and three payees across the deployment; in the *fresh* regime every attack uses a new endpoint.

Out of scope. Compromise of the orchestrator or executors, side channels, attacks on the reviewer's interface, and threshold probing by an adaptive attacker.

IV. ALIZA DESIGN

A. Decision point and context

ALIZA sits between the agent and its tool executors as a combined PDP and PEP in the NIST ZTA sense [19] (Fig. 2). For an episode run by agent α on task type τ, it keeps the context

$$c_t = \big(U_t,\, S_t,\, a_{t-1},\, D_t\big), \tag{5}$$

updated after each executed call by

$$U_{t+1} = U_t \vee \mathrm{untr}(a_t), \tag{6}$$

$$S_{t+1} = \max\big(S_t, \mathrm{sens}(a_t)\big), \tag{7}$$

$$D_{t+1} = D_t + n_t\,\mathbf{1}[a_t = \texttt{delete_file}], \tag{8}$$

with $U_1 = 0$, $S_1 = 0$, $D_1 = 0$, $a_0 = \langle \textsc{start} \rangle$. U_t and S_t form a coarse, conservative taint: once untrusted or sensitive data enters the context, everything after is treated as possibly derived from it. Fig. 3 shows the propagation for the email-triage example from the introduction.

B. Scope

A call q_t with $a_t \notin \mathscr{T}_\tau$ is denied outright. Scope is not learned; it is granted per workflow by an administrator, so learning cannot widen it (Proposition 1).

C. Risk features

Each in-scope call gets five features.

Sequence surprise: A per-task bigram model with add-β smoothing ($\beta = 0.1$):

$$\hat{P}(a_t \mid a_{t-1}, \tau) = \frac{n_\tau(a_{t-1}, a_t) + \beta}{\sum_{a \in \mathscr{A}} n_\tau(a_{t-1}, a) + \beta|\mathscr{A}|}, \tag{9}$$

$$f_{\mathrm{seq}} = \min\Big(-\tfrac{1}{6}\ln \hat{P}(a_t \mid a_{t-1}, \tau),\ 1.5\Big). \tag{10}$$

An unseen transition from a well-observed predecessor has $\hat{P} \approx \beta/N$; with $N = 1000$ observations this gives $-\ln \hat{P} \approx 9.2$ and hits the cap.

Provenance-to-sink flow: For any sink tool (email, HTTP post or payment) with an external destination,

$$f_{\mathrm{flow}} = \mathbf{1}[\mathrm{sink}(a_t) \wedge \mathrm{ext}(d_t)] \times \big(0.25U_t + 0.25\,\mathbf{1}[S_t \geq 1] + 0.5\,\mathbf{1}[S_t \geq 2]\big). \tag{11}$$

Unlike a hard IFC rule, this feature only raises risk; the decision still depends on the others. Payments count as sinks, so a finance run that queried the database ($S = 2$) before paying carries $f_{\mathrm{flow}} = 0.75$ even when benign; Section VII-E.2 shows the cost of this choice.

Destination novelty: With a confirmation mass $\kappa(\alpha, d)$ per agent-destination pair (Section IV-F),

$$f_{\mathrm{nov}} = \mathbf{1}[\mathrm{ext}(d_t)]\big(1 - \min(1, \kappa(\alpha, d_t))\big). \tag{12}$$

Amount deviation: For payments with log-amount $x = \ln x_t$, using the agent-payee history if it exists, else the agent's history (mean μ, standard deviation σ; at least three samples, else $f_{\mathrm{amt}} = 0.5$):

$$f_{\mathrm{amt}} = \min\Big(\frac{|x - \mu|}{3(\sigma + 0.2)},\ 1.5\Big). \tag{13}$$

Bulk-action rate: For deletions with per-agent observed maximum $D_\alpha^{\max}$ (initialized to 3):

$$f_{\mathrm{rate}} = \min\Big(\tfrac{1}{1.5}\max\big(0, \ln \tfrac{D_t + n_t}{D_\alpha^{\max}}\big),\ 3\Big). \tag{14}$$

A deletion ten times larger than anything seen scores $\ln 10/1.5 = 1.54$; a hundredfold one hits the cap.

D. Contextual trust decay and decision

Risk is a weighted sum, scaled up once untrusted content is in context:

$$r_t = \gamma(c_t) \sum_k w_k f_k, \qquad \gamma(c_t) = 1 + g_U\, U_t, \tag{15}$$

with $w = (w_{\mathrm{seq}}, w_{\mathrm{flow}}, w_{\mathrm{nov}}, w_{\mathrm{amt}}, w_{\mathrm{rate}}) = (0.6, 1.2, 1.0, 0.8, 1.0)$ and $g_U = 0.5$. These weights were set by hand before any attack evaluation and were not tuned on test seeds; Section VII-C.2 perturbs them. The decision is

$$\delta(q_t) = \begin{cases} \textsc{deny}, & a_t \notin \mathscr{T}_\tau \text{ or } r_t \geq \theta_2, \\ \textsc{step-up}, & \theta_1 \leq r_t < \theta_2, \\ \textsc{allow}, & r_t < \theta_1. \end{cases} \tag{16}$$

The maximum attainable score is bounded:

$$r_t \leq (1 + g_U) \sum_k w_k f_k^{\max} = 1.5\,(0.9 + 1.2 + 1.0 + 1.2 + 3.0) = 10.95. \tag{17}$$

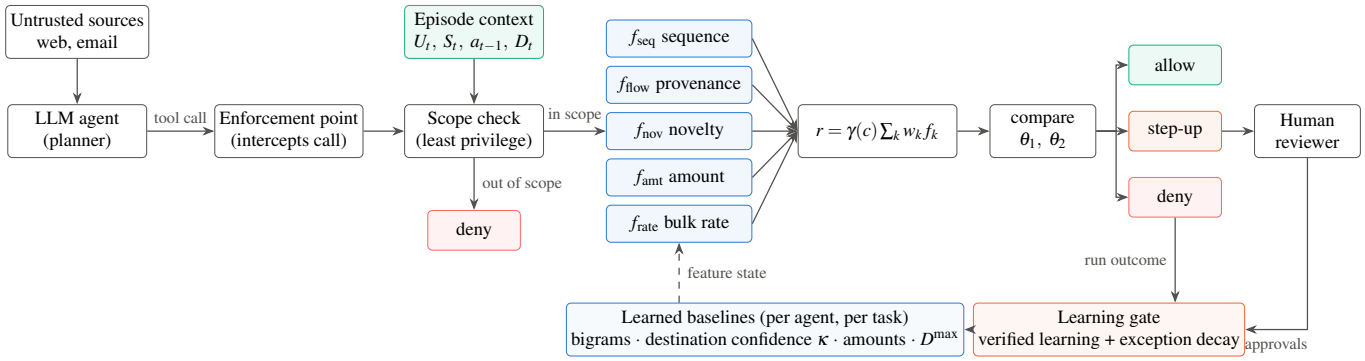


Figure 2. ALIZA architecture. Every tool call is intercepted, scope-checked, scored by five learned features with contextual trust decay $\gamma(c)$, and allowed, escalated or denied. Only verified actions reach the learned baselines, and human-approved exceptions are discounted.

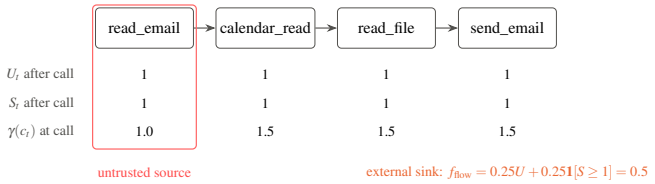


Figure 3. Context propagation in an email-triage episode. Reading mail sets $U = 1$ and $S = 1$; every later call is scored with $\gamma = 1.5$, and the external send carries flow risk 0.5.

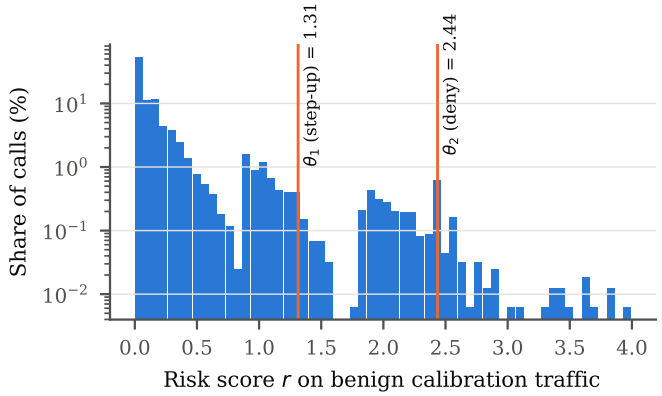


Figure 4. Risk-score distribution on benign calibration traffic (log scale) and the resulting thresholds.

E. Calibration from benign traffic only

ALIZA never sees attacks when it picks thresholds. On three calibration seeds, a shadow instance learns from 400 benign warm-up episodes and then scores the calls of 1500 further benign episodes, giving $N = 15{,}977$ scores $r^{(1)}, \ldots, r^{(N)}$ with empirical distribution $\hat{F}_N$. For a target deny rate ε_d and step-up rate ε_s per call,

$$\theta_2 = \hat{F}_N^{-1}(1 - \varepsilon_d), \qquad \theta_1 = \hat{F}_N^{-1}(1 - \varepsilon_d - \varepsilon_s). \tag{18}$$

The defaults $\varepsilon_d = 0.5\%$ and $\varepsilon_s = 3\%$ give $\theta_1 = 1.31$ and $\theta_2 = 2.44$ (Fig. 4). Calibration fixes the operator's friction budget; attack resistance is whatever follows. Theorem 1 bounds how far the realized rates can drift from the targets.

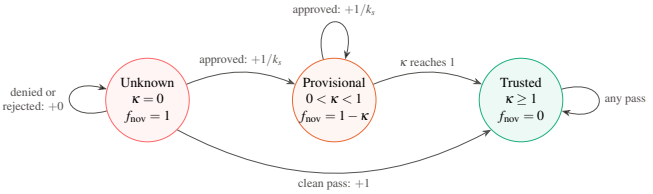


Figure 5. Destination trust as a state machine. A clean pass trusts a destination at once; human approvals move it towards trust in steps of $1/k_s$; denials leave it unchanged.

F. Learning safeguards

Verified learning. Let E_e be the executed calls of episode e and $A_e \subseteq E_e$ those approved at step-up. The baselines learn from

$$V_e = \begin{cases} E_e, & \text{no call in } e \text{ was denied,} \\ A_e, & \text{otherwise.} \end{cases} \tag{19}$$

An attacker run that is eventually caught teaches nothing except what a human signed off on.

Exception decay. A human approval lets one action through; it should not make the destination as trusted as one that passed without question. For each $q \in V_e$ with external destination d,

$$\kappa(\alpha, d) \leftarrow \kappa(\alpha, d) + \begin{cases} 1, & q \notin A_e, \\ 1/k_s, & q \in A_e, \end{cases} \tag{20}$$

with $k_s = 3$. Bigram counts, amount histories and $D_\alpha^{\max}$ update from every $q \in V_e$. Fig. 5 shows the resulting destination states.

Quarantine mode (ALIZA-Q). A stricter variant in which approved calls update *only* κ (still at $1/k_s$) and never the bigram, amount or bulk baselines.

G. Algorithm and control flow

Algorithm 1 gives the per-call procedure, and Fig. 6 the full control flow including the learning gate.

V. FORMAL PROPERTIES

Proposition 1 (Scope invariance)**.** *For every history of learning updates, every call with $a_t \notin \mathcal{T}_\tau$ is denied. Hence an attack whose goal call is out of scope has ASR exactly 0.*

Algorithm 1 ALIZA per-call authorization and learning

Require: call $q_t = (a_t, d_t, x_t, n_t)$, context c_t, baselines $\mathscr{B}$
if $a_t \notin \mathscr{T}_\tau$ **then return** DENY
end if
compute $f_{\text{seq}}, f_{\text{flow}}, f_{\text{nov}}, f_{\text{amt}}, f_{\text{rate}}$ from $c_t, \mathscr{B}$
$r_t \leftarrow (1 + g_U U_t) \sum_k w_k f_k$
if $r_t \geq \theta_2$ **then return** DENY
else if $r_t \geq \theta_1$ **then**
    if reviewer approves **then** add q_t to A_e; **return** ALLOW
    else return DENY
    end if
else return ALLOW
end if
on episode end:
$V_e \leftarrow E_e$ if no denial, else A_e ▷ Eq. (19)
for $q \in V_e$ **do**
    $\kappa(\alpha, d_q)$ += $(1/k_s$ if $q \in A_e$ else $1)$
    if not (quarantine and $q \in A_e$) **then** update bigrams, amounts, $D_\alpha^{\max}$
    end if
end for

Proof. The scope test in (16) reads only $\mathscr{T}_\tau$, which no update in Algorithm 1 writes. The denial precedes any reviewer interaction, so no approval can override it. □

Class A2 in our benchmark is exactly this case, and its measured ASR is 0.0% in every configuration that contains a scope check (Table XIV).

Lemma 1 (Monotonicity in untrusted context)**.** *Fix the call q_t, the baselines and (S_t, a_{t-1}, D_t). Order decisions* ALLOW $\prec$ STEP-UP $\prec$ DENY. *Then $\delta(q_t)$ under $U_t = 1$ is at least as severe as under $U_t = 0$.*

Proof. Every $f_k \geq 0$ and f_{flow} is non-decreasing in U_t; $\gamma = 1 + g_U U_t$ is non-decreasing with $g_U \geq 0$. So r_t is non-decreasing in U_t, and (16) is a non-decreasing step function of r_t. □

Lemma 1 says untrusted input can never relax a decision. It does not say untrusted input always tightens one; the gain g_U controls how much (Section VII-C.2).

Assumption 1 (Stationary calibration)**.** Benign risk scores at evaluation time are drawn i.i.d. from the same distribution F as the calibration scores.

Assumption 1 is false in detail (scores within an episode are correlated, and baselines keep learning), so Theorem 1 is a reference point, not a guarantee.

Theorem 1 (Review-load bound)**.** *Under Assumption 1, with probability at least $1 - \eta$ over the calibration sample, the true per-call step-up rate $\rho_s = F(\theta_2) - F(\theta_1)$ and deny rate $\rho_d = 1 - F(\theta_2)$ satisfy*

$$|\rho_d - \varepsilon_d| \leq \varepsilon_N, \quad |\rho_s - \varepsilon_s| \leq 2\varepsilon_N, \quad \varepsilon_N = \sqrt{\frac{\ln(2/\eta)}{2N}}. \tag{21}$$

Proof. By the Dvoretzky–Kiefer–Wolfowitz inequality with Massart's constant [28, 29], $\Pr\big(\sup_r |\hat{F}_N(r) - F(r)| > \varepsilon\big) \leq 2e^{-2N\varepsilon^2}$. Setting the right side to η gives ε_N. On the complementary event, $|F(\theta) - \hat{F}_N(\theta)| \leq \varepsilon_N$ at both thresholds, and $\hat{F}_N(\theta_2) = 1 - \varepsilon_d$, $\hat{F}_N(\theta_2) - \hat{F}_N(\theta_1) = \varepsilon_s$ up to ties; the triangle inequality gives the claim. □

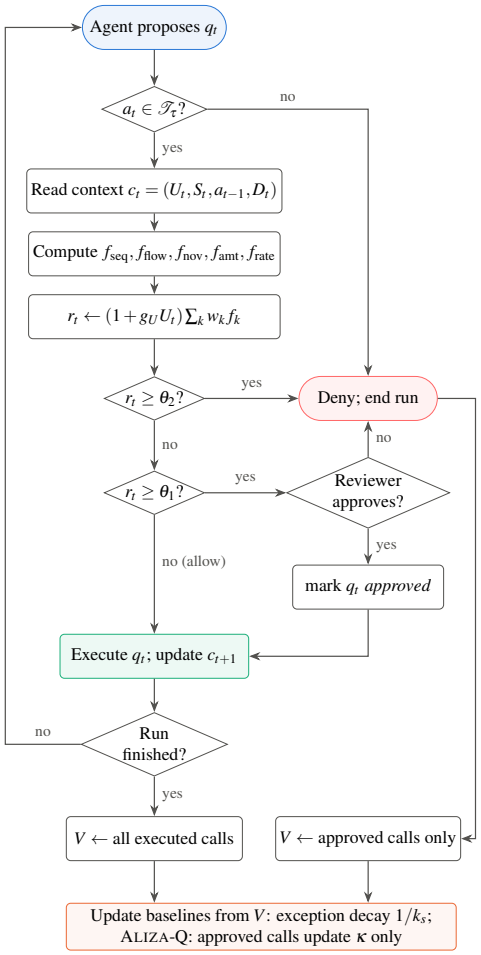


Figure 6. End-to-end control flow for one episode, from proposed call to baseline update.

With $N = 15{,}977$ and $\eta = 0.05$, $\varepsilon_N = 0.0107$, so the step-up rate should lie within $3\% \pm 2.1$ points. The measured friction on test seeds, 3.58 step-ups per 100 benign calls, sits inside this band.

Proposition 2 (Attempts bought by exception decay)**.** *Consider one attacker endpoint d that never appears in benign traffic, and assume every attempt to reach d is escalated while $\kappa(\alpha, d) < 1$ and each escalation is approved independently with probability p. Then d becomes fully trusted after k_s approvals; the number of attempts M until then is negative binomial with*

$$\mathbb{E}[M] = \frac{k_s}{p}, \qquad \mathrm{Var}[M] = \frac{k_s(1-p)}{p^2}. \tag{22}$$

Proof. Each approval adds $1/k_s$ to κ by (20); rejections end the episode with a denial, so by (19) only approved calls are learned and the rejected call adds nothing. Trust therefore

Table IV
PER-DECISION COST AND STATE SIZE

Component	Time per call	State
Scope check	$O(1)$	$O(\sum_\tau \lvert\mathscr{T}_\tau\rvert)$
f_{seq}	$O(\lvert\mathscr{A}\rvert)$	$O(\lvert\text{tasks}\rvert\,\lvert\mathscr{A}\rvert^2)$
f_{flow}	$O(1)$	$O(1)$ per episode
f_{nov}	$O(1)$	$O(\#\text{agent-destination pairs})$
f_{amt}	$O(h)$; $O(1)$ with Welford	$O(\#\text{payments})$
f_{rate}	$O(1)$	$O(\lvert\mathscr{G}\rvert)$
Learning gate	$O(\lvert V_e\rvert)$ per episode	–

requires exactly k_s approvals, and the number of Bernoulli(p) trials until the k_s-th success is negative binomial with the stated moments. □

With $p = 0.3$ (our mimicry reviewer setting), $k_s = 1$ hands over an endpoint after 3.3 attempts on average and $k_s = 3$ after 10 ± 4.8. Exception decay slows trust creep by a constant factor; it does not stop it. The proposition is about the novelty route only; the other baselines admit approved calls at full weight unless quarantine is on, which is why measured creep is faster than this model predicts (Section VII-D).

Proposition 3 (What verified learning admits)**.** *Let $\mathscr{M}$ be the set of malicious calls that ever enter V_e for some episode. Then*

$$|\mathscr{M}| \le \sum_{e \in attack} \Big(|A_e \cap mal| + \mathbf{1}[e \text{ had no denial}] \cdot |E_e \cap mal| \Big). \tag{23}$$

Under quarantine, the bigram, amount and bulk baselines receive only the second term.

Proof. Immediate from (19): a denied episode contributes only A_e, a clean one contributes E_e. Quarantine removes A_e from every update except κ. □

A clean malicious episode is a successful attack that never reached step-up, so the second term is bounded by the number of fully allowed attacks. Poisoning therefore comes only from attacks that already succeeded or that a human approved; verified learning cannot stop either, and Section VII-D measures the consequence.

A. Complexity

Table IV summarizes cost. Each decision performs a constant number of dictionary lookups plus one pass over a bigram row of at most $|\mathscr{A}|$ entries. The amount feature computes a mean and deviation over the agent-payee history; our implementation recomputes these each time, which is linear in history length, though the measured latency stayed flat over 6000 episodes (Section VII-E.4). Welford's online update would make it constant.

B. Implementation

The reference implementation is pure Python with NumPy, and the decision path is short enough to quote in full (Listing 1). Table V lists the artefact's modules. Scope is checked before any feature is computed, so out-of-scope calls never touch learned state, matching Proposition 1.

Table V
ARTEFACT MODULES

File	Lines	Role
`aliza_sim.py`	690	tools, workflows, attacks, defences, core experiments
`aliza_extra.py`	326	instrumented runner, sweeps, ROC, significance, layering
`trace.py`	21	worked-example extraction
`cost_analysis.py`	28	operator cost model
`make_figs*.py`	336	all result figures

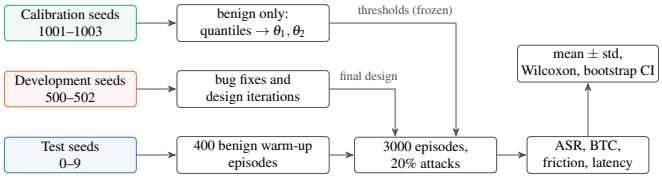


Figure 7. Evaluation pipeline. Thresholds come from benign-only calibration seeds; design changes were made on development seeds; reported numbers come from test seeds.

Table VI
TOOL CATALOGUE

Role	Tools (sensitivity of data read)
Untrusted source	search_web (0), read_email (1)
Read	read_file (1), list_dir (0), db_query (2), read_secret (3), calendar_read (0)
Act	run_code, write_file, calendar_write, delete_file
Sink	send_email, http_post, payment_transfer

```python
def risk(self, call, ctx):
    a = ctx.ep["agent"]
    f = dict(seq=self.f_seq(ctx.ep["task"], ctx.prev,
     call["tool"]),
             flow=self.f_flow(call, ctx), nov=self.f_nov(
     call, a),
             amt=self.f_amt(call, a), rate=self.f_rate(
     call, ctx))
    base = sum(self.W[k] * f[k] for k in self.use)
    gamma = 1.0 + self.G_U * ctx.U          # contextual
     trust decay
    return gamma * base, f

def decide(self, call, ctx):
    if call["tool"] not in ctx.ep["scope"]: return "deny",
      99.0
    r, _ = self.risk(call, ctx)
    if r >= self.t2: return "deny", r
    if r >= self.t1: return "stepup", r
    return "allow", r
```

Listing 1. Core of the ALIZA decision (from `aliza_sim.py`).

VI. EXPERIMENTAL SETUP

Fig. 7 shows the evaluation pipeline and the separation of seeds.

A. Tools and workflows

Table VI lists the 14 tools. Five benign task types each have an administrator-granted scope and weighted canonical paths (Table VII). Noise skips a step with probability 0.05 and inserts a random in-scope detour with probability 0.10.

Arguments. Benign traffic is not trivially separable from

Table VII
BENIGN WORKFLOWS: SCOPE AND CANONICAL PATHS (WEIGHTS)

Workflow	Granted scope $\mathscr{T}_\tau$	Canonical paths
research	search_web, read_file, write_file, list_dir, run_code	search→search→write (0.5); search→read_file→write (0.3); list→read_file→search→run→write (0.2)
email triage	read_email, calendar_read, calendar_write, send_email, read_file	read_email→cal_read→cal_write→send (0.45); read_email→send (0.35); read_email→read_file→send (0.20)
data report	db_query, run_code, write_file, send_email, read_file	db→run→write→send (0.6); db→db→run→write (0.4)
devops	list_dir, read_file, run_code, write_file, delete_file, read_secret, http_post	list→read_file→run→write (0.5); list→delete→write (0.2); read_secret→run→http_post internal (0.3)
finance	db_query, read_email, payment_transfer, write_file	db→pay→write (0.6); read_email→db→pay (0.4)
vendor onboarding†	read_email, read_file, write_file, send_email, db_query	read_email→read_file→write→send (0.6); read_email→db→write→send (0.4)

† introduced only in the drift experiment (Section VII-E.1).

attacks. Email triage sends internally 55% of the time, to a known external contact 40%, and to a brand-new contact 5%. Other workflows send internally 85%, to known contacts 13%, to new contacts 2%. Each agent has 5 payees with log-mean amount drawn from $\mathscr{U}(6,9)$ and log-standard deviation 0.35; 3% of payments go to a new payee with log-amount $\mathscr{N}(7.5, 0.6^2)$. Benign deletions remove 1–3 files, and devops legitimately reads a secret and posts it to an internal endpoint.

B. Attacks

Table VIII lists the five classes, injected right after the first untrusted read (indirect injection) or at a random point (A4, A5), into a carrier workflow where the attack is plausible.

C. Benchmark statistics

Table IX summarizes the volume of traffic behind each number.

D. Reviewer model

A benign step-up is approved with probability 0.97; the 3% rejections fail the task. A malicious step-up is approved with probability p_{fool}: 0.10 for A1, A2 and A5, which look obviously wrong, and 0.30 for A3 and 0.35 for A4, which look routine. Section VII-D.3 sweeps p_{fool} from 0 to 1.

E. Baselines

Table X configures each baseline. The sequence detector's threshold is the smallest τ that keeps benign completion at or above 95% on calibration seeds, a matched operating point; Section VII-C also compares full threshold sweeps.

F. Parameters and protocol

Table XI collects every parameter. Each run uses 400 benign warm-up episodes (onboarding), then 3000 evaluation episodes of which 20% carry an attack (≈600 attacks). We report means and standard deviations over 10 test seeds (0–9). Design iterations used development seeds (500–502), thresholds came from calibration seeds (1001–1003), and Section VIII-A records where test results informed the design. For paired comparisons we use the Wilcoxon signed-rank test [30] over the 10 seeds and a percentile bootstrap [31] (10,000 resamples) for 95% confidence intervals of the mean difference. Latency is the wall-clock cost of one authorization decision in Python 3.13 on a 2-vCPU cloud container, excluding the LLM and tool execution.

VII. RESULTS

A. RQ1: Main comparison

Table XII gives the headline numbers. Static RBAC stops only scope escalation (ASR 67.3%). The sequence detector, held to 95% benign completion, stops little (56.1%). RBAC + IFC rules stop every A1, A2 and A5 attack but almost no fraud, for 31.3% overall. ALIZA reaches 19.0% under the campaign and 13.5% with fresh endpoints, at 93.8% benign completion and 3.6 step-ups per 100 benign calls. ALIZA-Q reaches 9.9% and 5.7% but completes only 81% of benign tasks.

Statistical significance: Table XIII compares ALIZA with each alternative seed by seed. ALIZA has lower ASR than the rule baseline in 9 of 10 seeds (mean difference -12.3 points, 95% CI $[-15.9, -8.4]$, $p = 0.004$) and lower ASR than the sequence detector in all 10. The price is also significant: ALIZA completes 3.3 points fewer benign tasks than the rule baseline, lower in all 10 seeds ($p = 0.002$). Against the sequence detector the completion difference is not significant at 5% ($p = 0.084$). With 10 pairs the smallest attainable two-sided Wilcoxon p-value is 0.002.

Where the gain comes from: Table XIV breaks ASR down by class. ALIZA's advantage over the rule baseline is entirely in A3 and A4: it cuts mimicry exfiltration from 60.6% to 43.9% (25.7% with fresh endpoints) and low-and-slow fraud from 96.6% to 20.0%. On A1 and A5, where a crisp rule exists, the rule baseline is better: 0.0% against ALIZA's 8.0% and 22.5%. The layered configuration takes the best of both: 0.0% on A1, A2 and A5, 20.0% on A3 and 17.3% on A4. Fig. 8 shows the same data for the single-mechanism defences.

How attacks are stopped: Fig. 9 classifies every attack episode by its outcome (pooled over seeds, $n \approx 1200$ per class). For ALIZA alone, two thirds of A1 attacks die at the scope check

Table VIII
ATTACK CLASSES

Class	Injected calls (goal call last)	Carrier workflows	What makes it hard
A1 direct exfil	read_secret → http_post to attacker	research, email triage, devops	in scope for devops
A2 scope escalation	payment $\ln x \sim \mathcal{N}(9.5, 0.5^2)$ or 20–200 deletions	research, email triage, data report	nothing (scope catches it)
A3 mimicry exfil	read_file → send_email to attacker	email triage, data report	in-scope tools, common transition
A4 low-slow fraud	payment to attacker payee, $\ln x \sim \mathcal{N}(\bar{\mu}_\alpha, 0.3^2)$	finance	label-clean, normal amount
A5 mass delete	30–300 deletions	devops	in scope

Table IX
BENCHMARK STATISTICS (CAMPAIGN REGIME, ALIZA RUN)

Quantity	Value
Tools / workflows / attack classes	14 / 5 / 5
Agents; contacts and payees per agent	6; 8 and 5
Warm-up episodes per seed (benign)	400
Evaluation episodes per seed	3000
Attack episodes per seed	592–607
Attack episodes per class, 10 seeds pooled	1181–1238
Benign calls scored, 10 seeds pooled	97,109
Benign calls per benign episode	≈4.05
Calibration scores (3 seeds)	15,977

Table X
BASELINE CONFIGURATIONS

Baseline	Rule
No defence	allow everything
Static RBAC	deny $a_t \notin \mathcal{T}_\tau$
RBAC + IFC rules	RBAC; deny external email/HTTP post when $S_t \geq 2$; deny payments > 8000; deny deletion of > 10 files
Sequence anomaly	deny if $-\ln \hat{P}(a_t \mid a_{t-1}, \tau) > 6.25$; bigrams learned online from every executed call
Layered	RBAC + IFC rules first; ALIZA scores whatever the rules allow

Table XI
PARAMETERS

Group	Parameter	Value
ALIZA	weights w (seq, flow, nov, amt, rate)	0.6, 1.2, 1.0, 0.8, 1.0
	trust-decay gain g_U	0.5
	exception decay k_s	3
	smoothing β	0.1
Calibration	ε_d, ε_s	0.5%, 3%
	θ_1, θ_2	1.31, 2.44
	scores N	15,977
Workload	agents	6
	warm-up / eval. episodes	400 / 3000
	attack share	20%
	campaign pool	3 endpoints, 3 payees
Reviewer	benign approval	0.97
	p_{fool} (A1, A2, A5 / A3 / A4)	0.10 / 0.30 / 0.35
Seeds	calibration / dev / test	1001–3 / 500–2 / 0–9

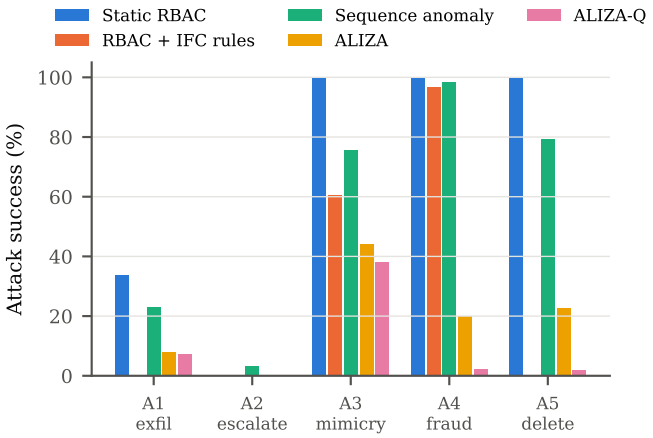


Figure 8. Attack success by class for each single-mechanism defence (campaign regime, 10 seeds).

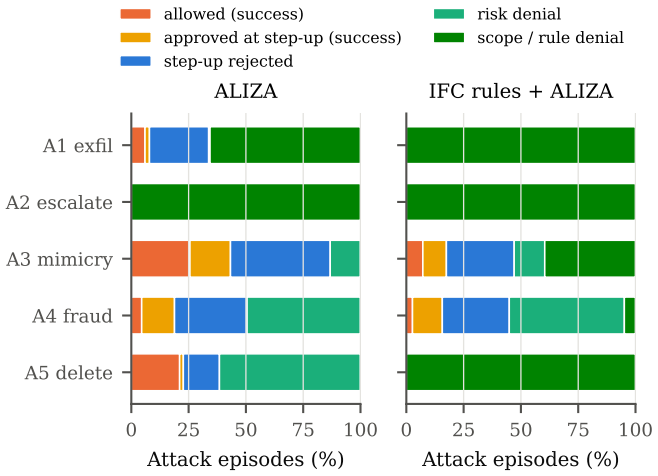


Figure 9. Outcome of every attack episode, campaign regime, pooled over 10 seeds. Orange and yellow segments are successes.

because two of their three carriers lack `read_secret`; the rest are mostly rejected at step-up. A3 is the hardest class: 25.6% pass without any escalation and 17.7% are approved by a fooled reviewer. A4 is mostly caught by outright risk denial (49.5%), and A5 by risk denial (61.6%), driven by the bulk-rate feature. In the layered system the rules absorb A1 and A5 entirely and 39.6% of A3.

Table XII
MAIN RESULTS (MEAN ± STD OVER 10 TEST SEEDS; 3000 EVALUATION EPISODES EACH, ≈600 ATTACKS)

	Campaign attacker			Fresh-endpoint attacker		Decision latency (μs)	
Defence	ASR (%) ↓	BTC (%) ↑	Friction ↓	ASR (%) ↓	BTC (%) ↑	median	p99
No defence	100.0 ± 0.0	100.0 ± 0.0	0.00	100.0 ± 0.0	100.0 ± 0.0	0.17	0.40
Static RBAC	67.3 ± 1.2	100.0 ± 0.0	0.00	66.2 ± 1.8	100.0 ± 0.0	0.25	0.64
RBAC + IFC rules	31.3 ± 1.8	97.1 ± 0.6	0.00	31.1 ± 2.0	97.1 ± 0.5	0.39	1.12
Sequence anomaly ($\tau = 6.25$)	56.1 ± 4.3	95.1 ± 1.5	0.00	55.2 ± 4.5	95.0 ± 1.9	0.88	3.59
ALIZA	$\mathbf{19.0 \pm 5.4}$	93.8 ± 1.6	3.58	$\mathbf{13.5 \pm 2.7}$	93.7 ± 1.9	3.68	59.9
ALIZA-Q (quarantine)	9.9 ± 2.5	81.2 ± 0.6	1.97	5.7 ± 0.9	81.7 ± 1.0	3.03	12.1
Layered (IFC rules + ALIZA)	7.4 ± 2.1	90.0 ± 2.3	3.31	–	–	–	–
Layered (IFC rules + ALIZA-Q)	3.4 ± 1.9	79.0 ± 0.4	1.87	–	–	–	–

Table XIII
PAIRED COMPARISON: ALIZA MINUS ALTERNATIVE (10 SEEDS)

Alternative	Metric	Δ (pts)	95% CI	p	ALIZA better
RBAC + IFC	ASR	−12.3	[−15.9, −8.4]	0.004	9/10
	BTC	−3.3	[−4.4, −2.4]	0.002	0/10
Seq. anomaly	ASR	−37.2	[−41.6, −31.8]	0.002	10/10
	BTC	−1.2	[−2.4, −0.1]	0.084	3/10
ALIZA-Q	ASR	+9.1	[+6.2, +12.7]	0.002	0/10
	BTC	+12.6	[+11.7, +13.5]	0.002	10/10
Layered	ASR	+11.5	[+8.2, +15.3]	0.002	0/10
	BTC	+3.9	[+2.8, +5.2]	0.002	10/10

Table XIV
ATTACK SUCCESS BY CLASS (%)

Defence	A1	A2	A3	A4	A5
Campaign regime					
Static RBAC	33.7	0.0	100.0	100.0	100.0
RBAC + IFC rules	**0.0**	**0.0**	60.6	96.6	**0.0**
Sequence anomaly	22.9	3.1	75.5	98.3	79.3
ALIZA	8.0	**0.0**	43.9	20.0	22.5
ALIZA-Q	7.1	**0.0**	38.1	2.0	2.0
Layered (IFC + ALIZA)	**0.0**	**0.0**	20.0	17.3	**0.0**
Layered (IFC + ALIZA-Q)	**0.0**	**0.0**	**15.3**	**1.5**	**0.0**
Fresh-endpoint regime					
RBAC + IFC rules	0.0	0.0	59.6	96.9	0.0
ALIZA	3.9	0.0	25.7	18.3	20.5
ALIZA-Q	4.2	0.0	21.1	1.0	2.1

A worked example: Fig. 10 replays a real A3 episode (test seed 0, evaluation episode 570). The injected `read_file` scores only 0.24: in-scope, common transition. The final `send_email` scores 1.96, landing in the step-up band. Its novelty is 0.67 rather than 1.0 because an earlier attack to the same campaign endpoint was approved by a fooled reviewer, adding $1/k_s = 1/3$ to κ: trust creep, in a single trace. Table XV shows the arithmetic. Had the endpoint been fresh, $f_{\text{nov}} = 1$ would have given $r = 1.5 \times 1.64 = 2.46 > \theta_2$: an outright denial instead of a step-up that a reviewer approves 30% of the time.

B. RQ2: Separability and feature attribution

Fig. 11 plots ROC curves of the call-level risk score: each class's goal calls against all 97,109 benign calls seen during evaluation. Table XVI lists AUC values. Pooled over classes, AUC is 0.970. A2 is perfectly separated by scope; the in-scope classes range from 0.948 (A5) to 0.979 (A4). These AUCs are high, yet operational ASR stays around 20%: at the deny threshold only about 0.5% of benign calls may be flagged, and the left end of the ROC curve, not its area, sets ASR.

Fig. 12 overlays the two score distributions. Most benign calls score below 0.5, but a tail reaches past θ_2; most attack goal calls sit between θ_1 and θ_2, which is why the reviewer matters so much.

Fig. 13 decomposes the mean score of in-scope goal calls into weighted feature contributions (including γ). Each class is carried by a different feature: novelty and flow for A1 and A3, flow, novelty and amount for A4, and the bulk rate for A5. No single feature covers all classes, which the ablation confirms.

Table XV
SCORE OF THE FINAL CALL IN FIG. 10

Feature	f_k	w_k	$w_k f_k$
f_{seq} (read_file → send_email)	0.063	0.6	0.038
f_{flow} ($U=1$, $S=1$, external)	0.500	1.2	0.600
f_{nov} ($\kappa = 1/3$)	0.667	1.0	0.667
f_{amt}, f_{rate}	0	–	0
$\sum_k w_k f_k$			1.305
$r = \gamma \sum_k w_k f_k$, $\gamma = 1.5$			**1.957**

$\theta_1 = 1.31 \le r < \theta_2 = 2.44$: step-up.

Table XVI
CALL-LEVEL SEPARABILITY OF THE ALIZA RISK SCORE

Attack goal calls	n	median r	AUC
A1 direct exfil (in-scope carriers)	408	2.10	0.964
A2 scope escalation	1209	∞ (scope)	1.000
A3 mimicry exfil	1181	1.93	0.956
A4 low-slow fraud	1070	2.30	0.979
A5 mass delete	1238	2.68	0.948
All classes	–	–	0.970

Benign reference: 97,109 calls; $\theta_1 = 1.31$, $\theta_2 = 2.44$.

C. RQ3: Operating points and sensitivity

Operating curves: A single operating point can flatter any method, so Fig. 14 sweeps thresholds: ALIZA scales (θ_1, θ_2)

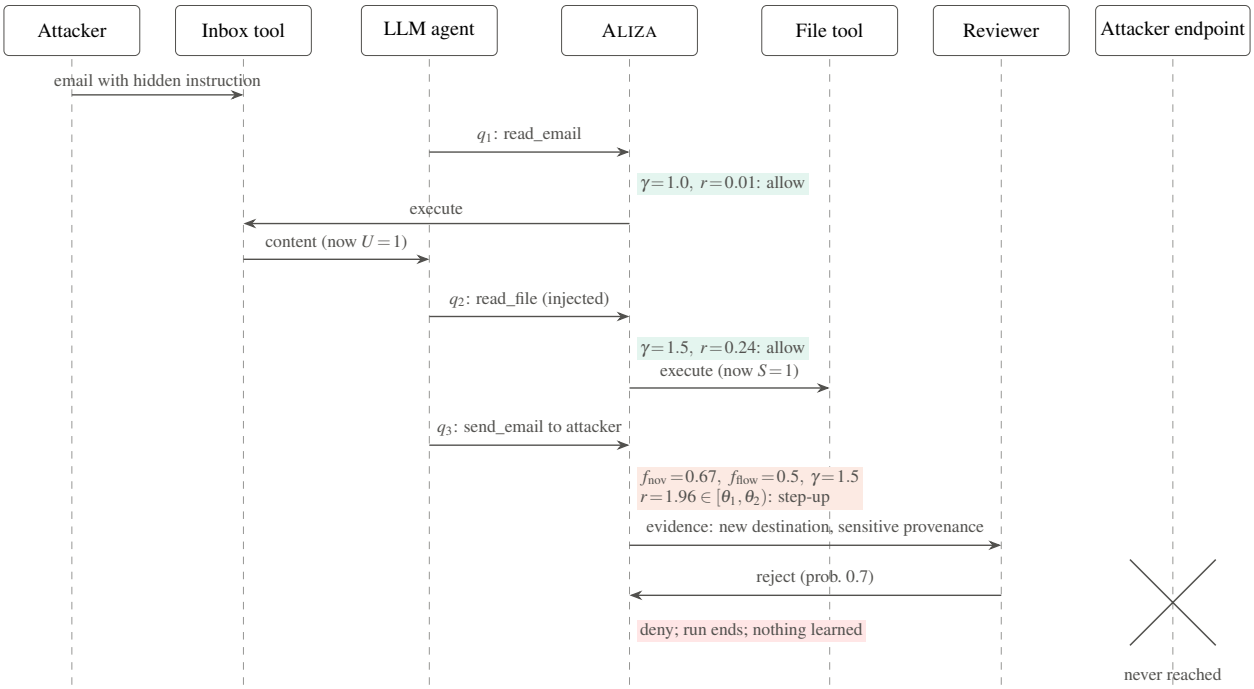


Figure 10. Sequence diagram of a real mimicry exfiltration from test seed 0. Scores are those ALIZA computed; the reviewer's decision is stochastic (rejection probability 0.7 for A3).

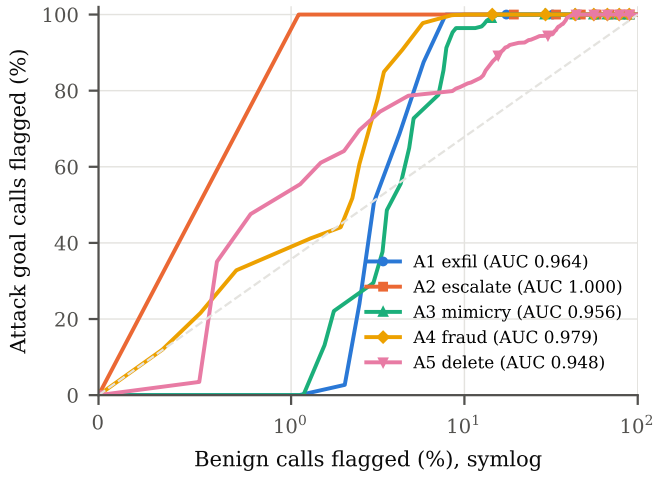


Figure 11. ROC curves of the call-level risk score per attack class (campaign regime, 10 seeds pooled). The x-axis is symmetric-log to show the low-false-positive region.

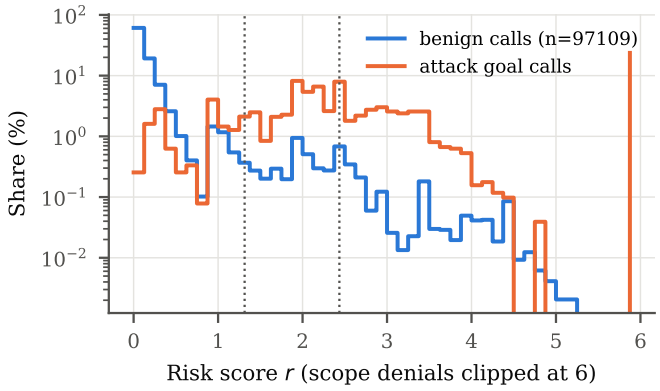


Figure 12. Risk-score distributions for benign calls and attack goal calls (dotted lines: θ_1, θ_2).

jointly by 0.5–2.6 and the sequence detector sweeps τ from 3 to 8 (five test seeds each). ALIZA's curve lies below the sequence detector's everywhere. Against the rule baseline the picture is tighter: interpolating ALIZA's curve at the rule baseline's 97.1% completion gives roughly 27% ASR versus 31.3%, a modest gain bought with about 3.4 step-ups per 100 benign calls.

Calibration targets: Fig. 15 and Table XVII vary ε_d and ε_s on a 3×3 grid, recalibrating each time. The step-up budget ε_s matters most: at 1% ASR is 41–56%, at 3% it falls to 15–26%, and beyond that the gain flattens (14.9–19.3% at 5%) while friction keeps rising. The deny budget ε_d trades benign completion for attack success roughly one-for-one. Realized friction tracks the step-up target within the band of Theorem 1 in every cell (0.87–1.11 at 1%, 3.44–3.62 at 3%, 4.81–5.40 at 5%).

Trust-decay gain: Table XVIII and Fig. 16 vary g_U, recalibrating thresholds each time. The result is counter-intuitive at first. Larger g_U raises *benign* scores too, because most benign workflows read untrusted content, so calibration pushes θ_2 up (1.72 at $g_U = 0$ to 4.87 at $g_U = 2$) and ASR rises from 8.7% to 50.0%. At $g_U = 0$, ASR is lowest but benign completion falls

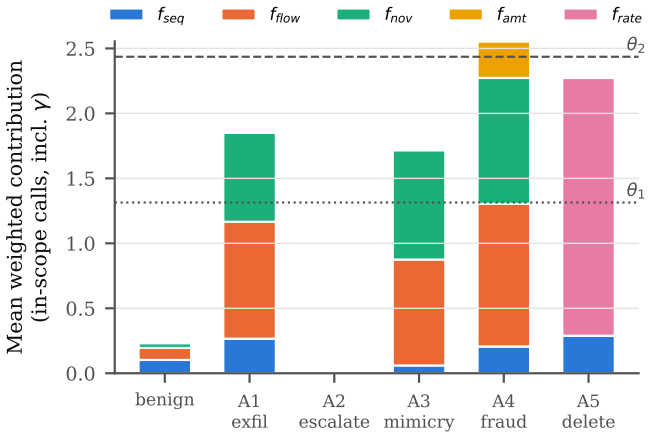


Figure 13. Mean weighted feature contribution for benign calls and each class's in-scope goal calls. A2 has no in-scope goal calls.

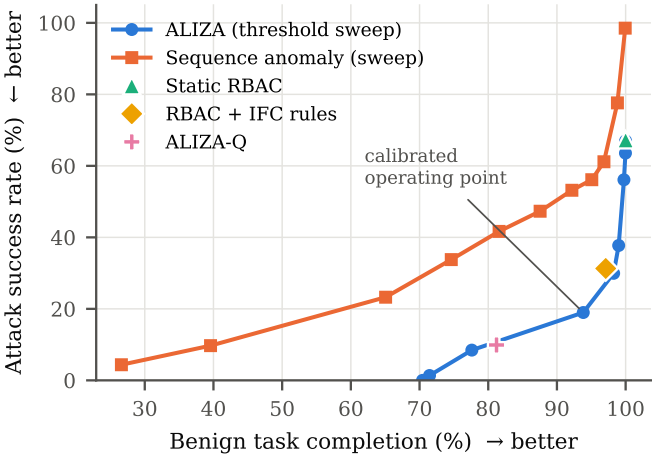


Figure 14. Attack success versus benign task completion (campaign regime). Curves sweep thresholds; markers are fixed policies.

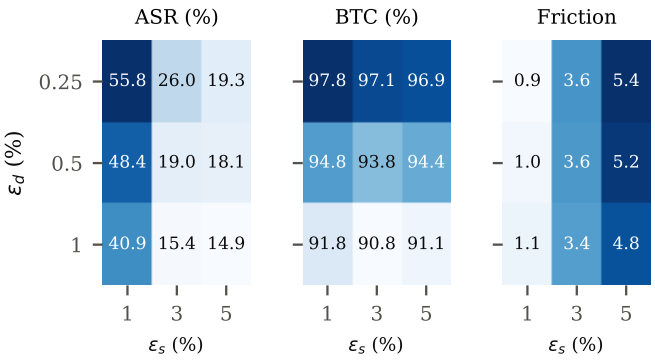


Figure 15. Effect of calibration targets (10 seeds per cell). Darker is larger.

Table XVII
CALIBRATION-TARGET GRID (10 SEEDS PER CELL)

ε_d	ε_s	θ_1	θ_2	ASR (%)	BTC (%)	Friction
0.25%	1%	2.25	2.57	55.8 ± 3.1	97.8 ± 0.8	0.87
0.25%	3%	1.36	2.57	26.0 ± 5.5	97.1 ± 0.8	3.62
0.25%	5%	1.07	2.57	19.3 ± 3.2	96.9 ± 0.7	5.40
0.5%	1%	2.16	2.44	48.4 ± 2.5	94.8 ± 1.7	0.99
0.5%	**3%**	**1.31**	**2.44**	**19.0 ± 5.4**	**93.8 ± 1.6**	**3.58**
0.5%	5%	1.06	2.44	18.1 ± 4.3	94.4 ± 1.0	5.24
1%	1%	2.01	2.41	40.9 ± 3.4	91.8 ± 1.0	1.11
1%	3%	1.22	2.41	15.4 ± 3.0	90.8 ± 1.8	3.44
1%	5%	1.04	2.41	14.9 ± 4.0	91.1 ± 2.1	4.81

Table XVIII
TRUST-DECAY GAIN SWEEP (RECALIBRATED, 10 SEEDS)

g_U	θ_1	θ_2	ASR (%)	BTC (%)	Friction
0.00	1.24	1.72	8.7 ± 1.5	79.9 ± 1.3	1.06
0.25	1.30	2.05	14.7 ± 4.1	81.6 ± 1.8	1.57
0.50	**1.31**	**2.44**	**19.0 ± 5.4**	**93.8 ± 1.6**	**3.58**
1.00	1.43	3.25	32.4 ± 4.1	96.0 ± 0.4	3.94
2.00	2.11	4.87	50.0 ± 2.7	97.0 ± 0.5	3.12

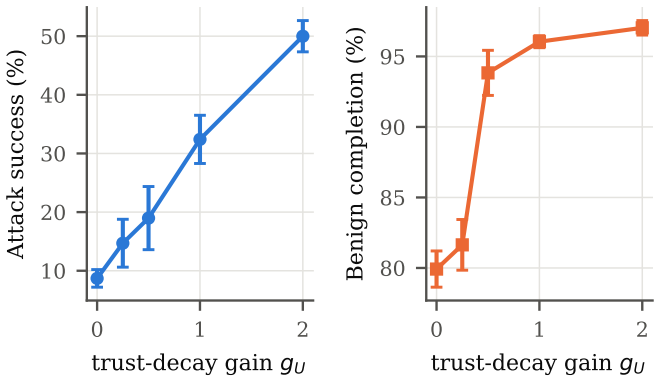


Figure 16. Effect of the trust-decay gain g_U (thresholds recalibrated for each value; error bars are std over 10 seeds).

to 79.9%. Because thresholds are quantiles of the benign score distribution, a feature that shifts benign and malicious scores together buys nothing; only features that separate them help. The default $g_U = 0.5$ sits at the knee where completion first exceeds 90%.

Feature weights: Fig. 17 draws 16 random weight vectors, each weight multiplied by a factor from $\mathcal{U}(0.7, 1.3)$, recalibrates, and runs five seeds. ASR ranges from 14.9% to 31.6% (mean 22.0%, s.d. 4.8) and completion from 92.1% to 97.7%. In 15 of 16 draws ALIZA still beats the rule baseline's 31.3% ASR, and in 2 draws it beats the rule baseline on ASR while matching or exceeding its 97.1% completion. The hand-set default is not special; most nearby weightings do similarly.

Ablation: Table XIX removes one component at a time (Fig. 18). Provenance flow and destination novelty carry most of the protection: removing either more than doubles ASR

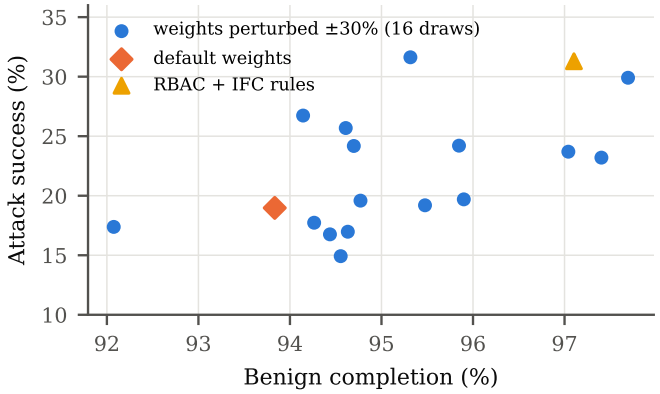


Figure 17. Robustness to feature weights: 16 draws with every weight perturbed by up to ±30%, recalibrated (5 seeds each).

Table XIX
ABLATION, CAMPAIGN REGIME (10 SEEDS)

Variant	ASR (%)	BTC (%)	Friction
ALIZA (full)	19.0 ± 5.4	93.8 ± 1.6	3.58
w/o flow	47.8 ± 2.9	99.9 ± 0.0	0.59
w/o novelty	42.4 ± 2.3	99.1 ± 0.3	2.41
w/o rate	35.3 ± 3.8	93.6 ± 1.6	3.48
w/o sequence	29.5 ± 2.2	97.7 ± 0.2	3.53
w/o exception decay	25.9 ± 4.7	95.2 ± 2.1	3.06
w/o amount	21.0 ± 3.1	97.3 ± 0.6	3.55
w/o verified learning	19.3 ± 2.7	90.4 ± 2.9	3.27
frozen (no learning)	4.7 ± 0.9	73.6 ± 0.5	0.77
quarantine (ALIZA-Q)	9.9 ± 2.5	81.2 ± 0.6	1.97

(47.8% and 42.4%). They are also what costs benign completion; without flow, completion is 99.9%. The bulk-rate feature is the only defence against in-scope mass deletion (ASR 35.3% without it). Removing the amount feature costs only 2 points of ASR and returns 3.5 points of completion, so in this benchmark it is close to break-even. Exception decay lowers ASR from 25.9% to 19.0%. Verified learning leaves ASR unchanged (19.3% without it) but improves completion from 90.4% to 93.8%; we did not isolate the cause. Turning learning off entirely gives the lowest ASR, 4.7%, but only 73.6% completion: a frozen baseline treats every legitimate new contact or payee as novel forever.

D. RQ4: Trust over time

Trust creep: Fig. 19 extends runs to 6000 episodes and plots ASR and BTC in 500-episode blocks. Learning works as intended for benign traffic: ALIZA's completion rises from 85.8% in the first block to 98.5% in the last. It also works for the attacker. Under the campaign, ALIZA's ASR climbs from 7.4% to 45.5%, passing the flat rule baseline (about 32%) after roughly 3000 episodes. Without exception decay the climb is faster (10.2% to 47.1%). Even with fresh endpoints ASR drifts from 7.0% to 23.4%, because approved malicious calls still feed the bigram, amount and bulk baselines; an approved mass deletion, for example, raises $D_\alpha^{\max}$. ALIZA-Q removes that second route: with fresh endpoints its ASR stays between 5.1% and 8.4% throughout. Under the campaign ALIZA-Q

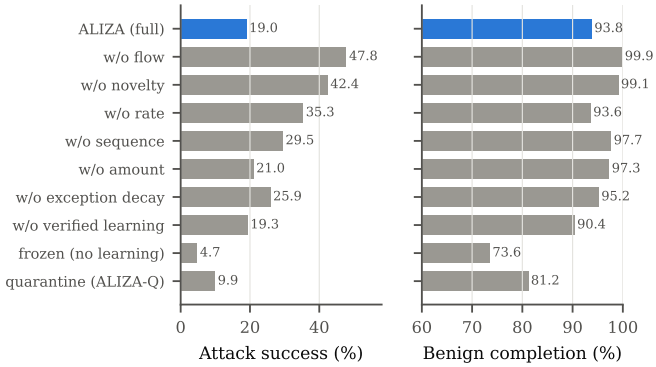


Figure 18. Ablation: attack success (left) and benign completion (right) for each variant.

Table XX
ATTACK SUCCESS (%) BY 500-EPISODE BLOCK OVER 6000 EPISODES

Configuration	1	3	6	9	12	BTC 1→12
RBAC + IFC rules	31.7	32.2	31.6	33.0	31.7	97.2→96.6
ALIZA, no decay, campaign	10.2	27.9	33.1	43.8	47.1	87.9→98.8
ALIZA, campaign	7.4	18.6	26.8	39.7	45.5	85.8→98.5
ALIZA, fresh	7.0	16.2	17.9	21.2	23.4	84.9→98.5
ALIZA-Q, campaign	6.8	8.9	13.8	24.4	23.5	77.5→86.5
ALIZA-Q, fresh	5.4	5.1	6.9	6.9	8.2	78.4→86.3

Table XXI
EXCEPTION-DECAY SWEEP OVER 6000 EPISODES (10 SEEDS)

	ASR (%)				
k_s	ep. 1–1000	all	ep. 5001–6000	BTC (%)	Friction
1	15.2	35.6 ± 4.5	48.0 ± 6.3	96.9 ± 1.1	2.79
2	10.8	29.9 ± 4.5	44.5 ± 5.0	96.5 ± 1.1	2.98
3	**9.8**	**29.3 ± 4.6**	**44.4 ± 5.3**	**96.2 ± 0.8**	**3.09**
5	10.5	26.1 ± 4.5	39.6 ± 4.0	94.1 ± 2.1	3.22
10	9.4	23.6 ± 6.0	36.7 ± 6.6	91.3 ± 1.7	3.77
∞	7.9	16.6 ± 4.2	23.3 ± 7.0	85.5 ± 1.5	3.74

still creeps (6.8% to 23.5%) through the discounted κ route of Proposition 2, and its completion recovers only slowly, from 77.5% to 86.5%. Table XX gives the block values behind Fig. 19.

Exception decay: Table XXI and Fig. 20 vary k_s over 6000-episode runs. Larger k_s lowers late-run ASR monotonically (48.0% at $k_s = 1$ to 36.7% at $k_s = 10$ in episodes 5001–6000) and costs completion (96.9% to 91.3%). Even $k_s = \infty$, where approvals never build destination trust, reaches 23.3% late in the run, because the other baselines still learn from approvals; only quarantine closes that route. At $k_s = 3$, the 6000-episode average ASR is 29.3%, against 19.0% over the standard 3000 episodes: run length matters as much as any parameter.

Reviewer reliability: Fig. 21 sets one p_{fool} for all classes. With a perfect reviewer ALIZA's ASR is 0.6%: almost every attack reaches step-up or deny. ALIZA beats the rule baseline, which

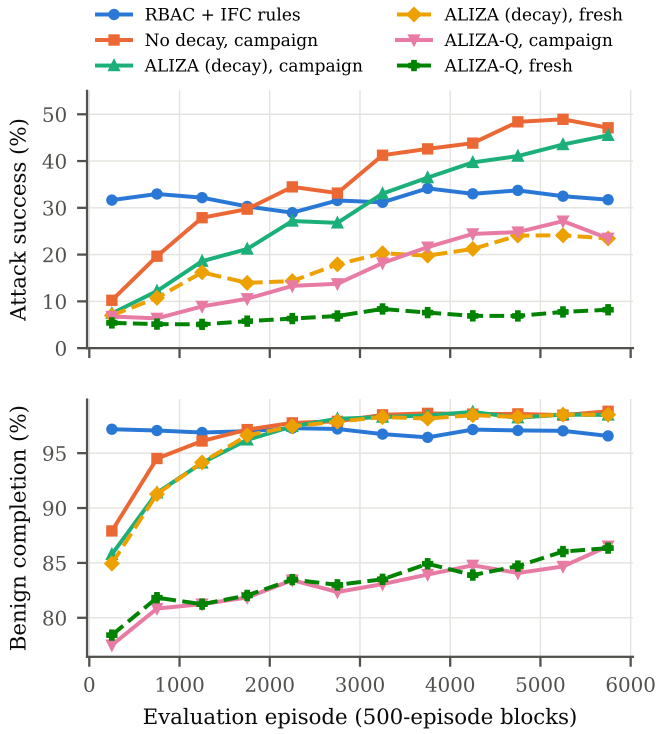


Figure 19. Trust creep over 6000 evaluation episodes (10 seeds). Top: attack success. Bottom: benign completion. Dashed lines: fresh endpoints.

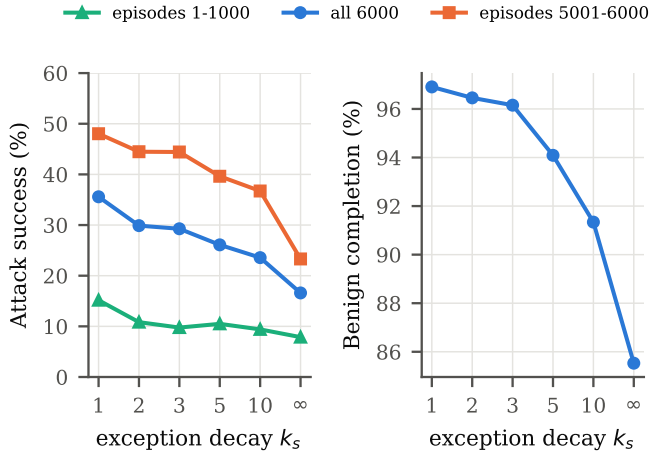


Figure 20. Exception decay k_s: attack success early, overall and late in 6000-episode runs (left) and benign completion (right).

Table XXII
ATTACK SUCCESS (%) UNDER REVIEWER ERROR AND ATTACK PRESSURE

p_{fool}	ALIZA	no decay	share	ALIZA	no decay	IFC	Seq.
0.0	0.6	0.4	5%	11.8	13.8	31.2	56.6
0.1	9.3	14.9	10%	13.1	19.6	31.9	56.6
0.2	18.4	24.8	20%	19.0	25.9	31.3	56.1
0.3	26.6	32.1	30%	25.1	31.2	31.4	58.0
0.5	38.1	42.8	40%	30.6	35.6	31.2	58.1
0.7	47.1	49.0					
1.0	53.5	56.2					

Left: one p_{fool} for all classes. Right: share of episodes carrying an attack.

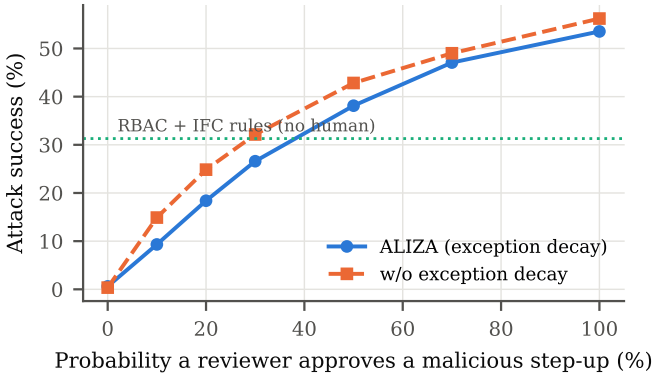


Figure 21. Attack success versus the probability that a reviewer approves a malicious step-up (campaign regime, 10 seeds).

uses no reviewer, only while p_{fool} stays below about 0.4. At $p_{\text{fool}} = 1$, where every escalated attack is approved, ASR is 53.5%, the part that only the deny threshold blocks. Exception decay helps most for unreliable-but-not-useless reviewers (18.4% versus 24.8% at $p_{\text{fool}} = 0.2$). ALIZA's value rests on the step-up screen showing reviewers the evidence (new destination, sensitive provenance, unusual amount) that makes an attack look wrong. Table XXII lists the values for this sweep and the next.

Attack pressure: Fig. 22 varies the share of attack episodes from 5% to 40%. Rule and sequence baselines are flat because they do not learn from attacks. ALIZA's ASR rises from 11.8% to 30.6%, meeting the rule baseline at 40%: more attacks mean more approved exceptions and faster creep. Exception decay keeps ALIZA 2–7 points below the no-decay variant at every rate.

E. RQ5: Drift, workflows and scale

Workflow drift: At episode 1500 we add the vendor-onboarding workflow (Table VII), which makes up half of later traffic and emails a brand-new external contact in half of its runs (Fig. 24, benign traffic only). With online learning, the share of denied benign runs falls from about 18% after warm-up to 5.5% before the change, peaks at 25.6%, and settles near 16.8%. It does not return to 5.5%, because a first email to a new contact after reading sensitive files is exactly what ALIZA escalates; learning cannot make the first contact familiar. A

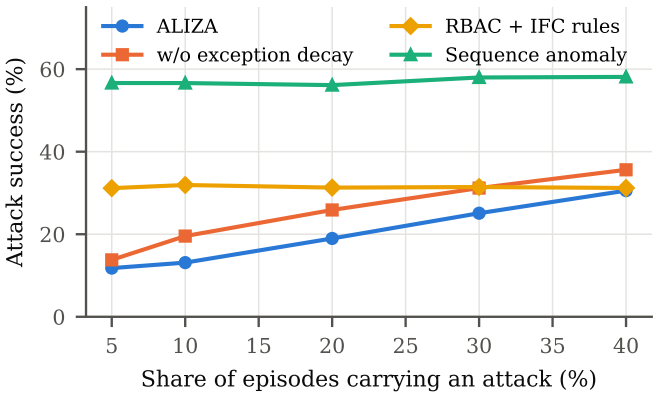


Figure 22. Attack success versus attack prevalence (campaign regime, 10 seeds).

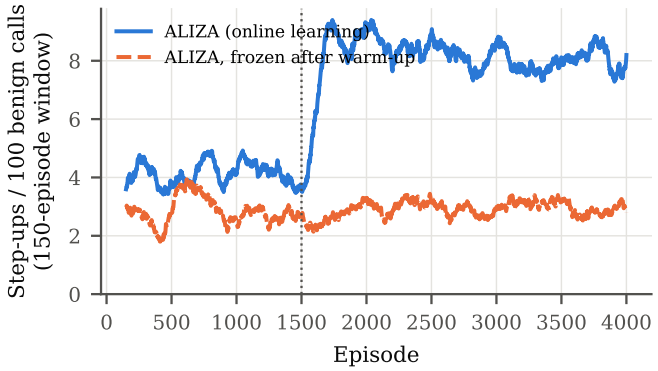


Figure 23. Review load (150-episode moving window) when a new workflow appears at episode 1500 (5 seeds).

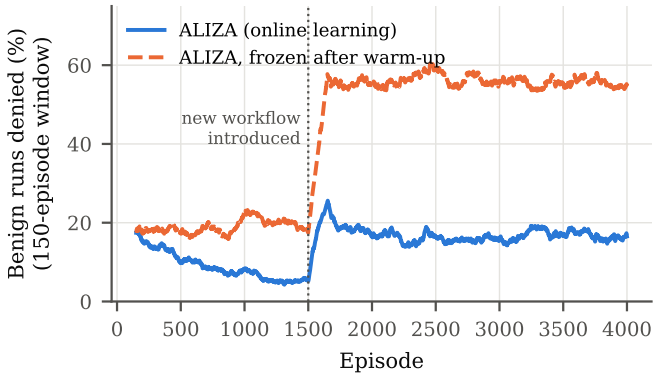


Figure 24. Denied benign runs (150-episode moving window) when a new workflow appears at episode 1500 (5 seeds).

baseline frozen after warm-up denies 55.9% of benign runs after the change. Fig. 23 shows the review load over the same run. With learning, friction rises from about 3.7 to a peak of 9.4 step-ups per 100 benign calls after the change and averages 8.3 afterwards, more than double the pre-change level; the frozen baseline shows lower friction (2.9) only because it denies outright what the learning system escalates. Drift therefore costs a learning authorizer review time, and a frozen one completed work.

Table XXIII
BENIGN COMPLETION (%) AND FRICTION BY WORKFLOW

	RBAC + IFC		ALIZA		ALIZA-Q	
Workflow	BTC	Fr.	BTC	Fr.	BTC	Fr.
research	100.0	0.0	100.0	0.00	100.0	0.00
email triage	100.0	0.0	92.3	5.83	91.3	5.59
data report	91.1	0.0	99.7	1.07	99.9	1.12
devops	100.0	0.0	100.0	0.00	100.0	0.00
finance	94.3	0.0	77.4	13.74	15.5	4.78

About 4800 benign episodes per workflow, pooled over 10 seeds.

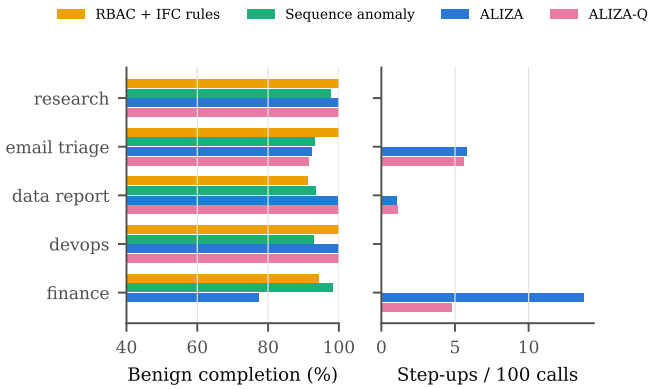


Figure 25. Benign completion and friction per workflow (10 seeds pooled).

Per-workflow behaviour: Table XXIII and Fig. 25 split benign completion and friction by workflow. ALIZA's cost is concentrated: research and devops run untouched (100% completion, zero friction), while finance completes only 77.4% with 13.7 step-ups per 100 calls and email triage 92.3% with 5.8. Finance pays because every payment is an external sink after a database read, so $f_{\text{flow}} = 0.75$ before any other feature fires, and because 3% of benign payments go to new payees. Quarantine is disastrous for finance: 15.5% completion, since approved payments to new payees and their amounts never join the baselines. The rule baseline instead pays in data reports (91.1%), where its flow rule blocks legitimate external report emails. A per-workflow weight for f_{flow} on payments, or pre-registered payees, are the obvious fixes.

Deployment size and warm-up: Table XXIV and Fig. 26 vary the number of agents (holding total traffic fixed) and the warm-up length. More agents means thinner per-agent baselines: ASR falls from 31.6% with 3 agents to 10.8% with 24, but completion falls from 95.8% to 85.2%, because each agent sees fewer of its own destinations and payees. Longer warm-up does the reverse: completion rises from 91.7% (100 episodes) to 97.6% (1600) and ASR from 17.9% to 22.3%. Both are the adaptation dilemma again: anything that makes baselines richer makes them more permissive.

Latency: Fig. 27 tracks median decision time over 6000 episodes on one seed. ALIZA stays flat at 3.3–3.5 μs per de-

Table XXIV
EFFECT OF DEPLOYMENT SIZE AND WARM-UP (10 SEEDS)

Setting	Value	ASR (%)	BTC (%)	Friction
Agents	3	31.6 ± 3.6	95.8 ± 1.8	2.92
	6	**19.0 ± 5.4**	**93.8 ± 1.6**	**3.58**
	12	13.5 ± 3.0	89.1 ± 2.1	3.97
	24	10.8 ± 1.3	85.2 ± 2.4	4.02
Warm-up	100	17.9 ± 3.6	91.7 ± 1.8	3.57
	200	17.1 ± 3.6	92.4 ± 1.8	3.62
	400	**19.0 ± 5.4**	**93.8 ± 1.6**	**3.58**
	800	21.1 ± 4.4	95.7 ± 1.3	3.41
	1600	22.3 ± 3.0	97.6 ± 0.7	3.01

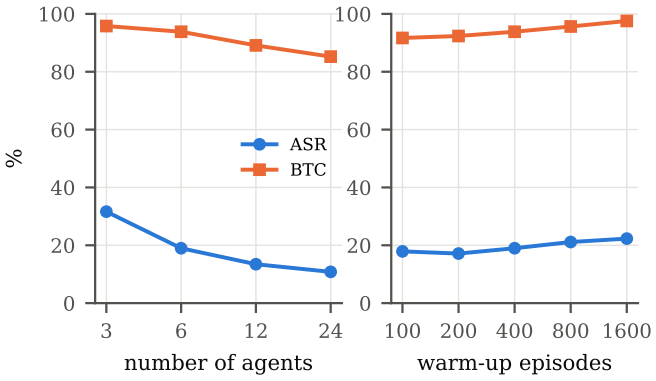


Figure 26. Attack success and benign completion versus number of agents (left) and warm-up length (right).

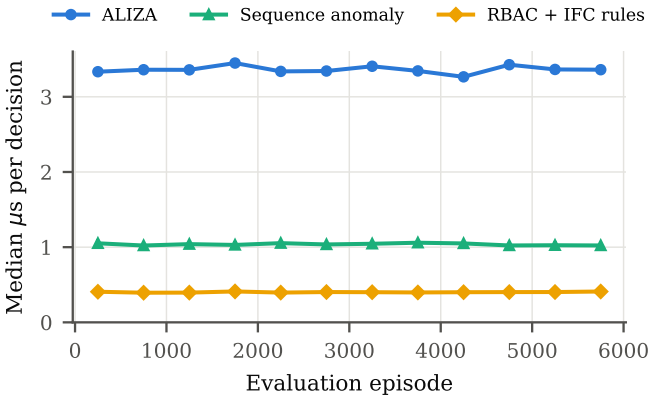


Figure 27. Median decision latency per 500-episode block as history grows (seed 0, unoptimized Python).

cision (overall median 3.36 µs, p99 27.7 µs), against 1.04 µs for the sequence detector and 0.40 µs for the rules. All three are negligible next to an LLM call, which takes hundreds of milliseconds. The real cost is human attention: 3.6 step-ups per 100 benign calls means one review every five or six workflows of five calls each.

F. RQ6: Layering rules and learning

Fig. 28 places every configuration in the ASR–BTC plane. Putting the rules in front of ALIZA lowers ASR from 19.0% to 7.4% (lower in all 10 seeds, $p = 0.002$), at a cost of 3.9 points

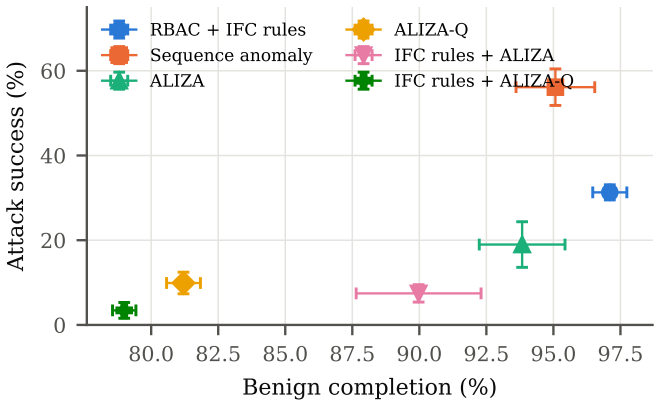


Figure 28. All configurations in the attack-success and benign-completion plane (campaign regime, mean ± std over 10 seeds).

Table XXV
EXPECTED EVENTS PER 1000 EPISODES (20% ATTACKS)

Configuration	Attacks succeed	Tasks broken	Reviews
RBAC + IFC rules	62.6	23.2	0.0
Sequence anomaly	112.3	39.4	0.0
ALIZA	38.0	49.3	115.8
ALIZA-Q	19.8	150.4	63.7
IFC rules + ALIZA	14.9	80.2	107.0
IFC rules + ALIZA-Q	6.9	168.0	60.5

Reviews counts benign step-ups only.

of completion (93.8% to 90.0%). With quarantine behind the rules, ASR drops to 3.4% but completion to 79.0%. No configuration dominates on both axes; the layered system is the strongest at the 90% completion level, and the plain rules remain the most usable.

G. Operator cost analysis

Which configuration should an operator pick? Let c_a, c_b and c_r be the costs of one successful attack, one broken benign task and one human review. Per 1000 episodes at 20% attack share, the expected cost of configuration π is

$$J(\pi) = 200\,c_a\,\mathrm{ASR}(\pi) + 800\,c_b\big(1-\mathrm{BTC}(\pi)\big) + 800\,\bar{n}\,c_r\,\mathrm{Friction}(\pi)/100, \tag{24}$$

where $\bar{n} \approx 4.05$ is the measured number of benign calls per benign episode. Dividing by c_b leaves two ratios, $\rho_a = c_a/c_b$ and $\rho_r = c_r/c_b$. Table XXV gives the three counts per 1000 episodes; Fig. 29 plots J/c_b against ρ_a for $\rho_r = 0.05$.

The minimizer of J changes with ρ_a. With reviews costing 5% of a broken task, the plain rules are best while an attack costs less than about 1.6 broken tasks; rules plus ALIZA are best from there up to about 12.6; rules plus ALIZA-Q above that. With free reviews, ALIZA alone is best only in a narrow band ($1.3 \le \rho_a < 1.6$); with reviews at 20% of a broken task, the switch points move to 2.0 and 10.0. For a deployment where one exfiltration or fraudulent payment is worth more than a dozen failed tasks, which describes most agents with payment or data access, the layered configuration with quarantine is the cost-minimizing choice despite its 79% completion.

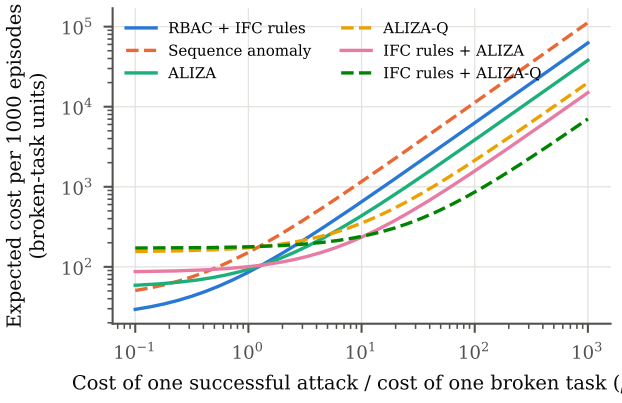


Figure 29. Expected cost per 1000 episodes versus the relative cost of a successful attack ($\rho_r = 0.05$). The lower envelope shows the best configuration for each cost ratio.

VIII. Discussion

A. Development log

We record the design changes because they shaped the results. The first version, run once on the test seeds before any change, let 35.5% of attacks through, worse than the rule baseline, because of an implementation bug (injected payments carried no destination, so novelty never fired) and a bulk-rate cap that scored a 300-file deletion like a 10-file one. After fixing both, the campaign regime exposed that a single fooled approval permanently trusted an attacker endpoint. We first tried discounting trust earned while untrusted content was in context; this made matters worse (34.4% versus 23.6% ASR on development seeds) because legitimate contacts are always learned after reading email. Exception decay, which discounts trust by *how* an action passed rather than *what* the context held, replaced it. Quarantine came last, after the test-seed creep curves. Because the test seeds were seen twice during development, they are not strictly untouched; the hand-set weights and calibration targets never changed after the first run, and the sensitivity analysis (Section VII-C.2) shows the conclusions do not hinge on them.

B. The adaptation dilemma

Every learned component in ALIZA sits on the same dial. Turned towards adaptation (more warm-up, fewer agents, low k_s), the system learns new contacts, payees and workflows, and completion reaches 97–98%; it also learns whatever a fooled reviewer approved. Turned towards suspicion (quarantine, high k_s, frozen baselines), it holds attack success near 5% but fails one benign task in five, and most finance tasks. We found no setting in this benchmark that avoids both. We think this dilemma is the right frame for learned zero-trust authorization: detection accuracy on day one (AUC 0.97 here) matters less than how the system's trust evolves under a stream of human decisions. Two directions look promising. First, *expiring trust*: confirmation mass that decays with time and must be renewed by clean use, bounding how long an absorbed exception survives. Second, *trust from outside the agent*: pre-registered destinations and payees from systems of record, so that novelty means "not in the CRM" rather than "not seen before".

C. Attack classes in detail

A1 (direct exfiltration). Whenever the carrier lacks `read_secret`, scope ends the attack. In devops, where reading secrets is legitimate, ALIZA relies on flow (sensitivity 3 data heading to an external host) and novelty. Of A1 episodes, 6.0% pass without escalation and 1.9% are approved by a fooled reviewer; with fresh endpoints A1 falls to 3.9%, so about half the leakage comes from campaign endpoints already trusted through creep. A deterministic rule (no secrets to unregistered hosts) closes this class completely, and should.

A2 (scope escalation). Solved by construction (Proposition 1); any defence with a scope check scores 0%.

A3 (mimicry exfiltration). The hardest class for every defence. Its tool sequence is a common benign one, its data has sensitivity 1 (below the rule baseline's threshold of 2), and email triage legitimately writes to new external contacts 5% of the time. Only the combination of a new destination and untrusted context separates it, and the resulting score lands in the step-up band, where a reviewer's 30% approval rate decides most outcomes. Value-level provenance, knowing that the email body came from the file the injected instruction requested, would separate it far better than our episode-level taint.

A4 (low-and-slow fraud). Invisible to the rule baseline by construction (normal amount, no sensitive data in the payment itself), and the class where ALIZA gains most: 96.6% to 20.0%. The new payee drives the catch; the amount feature adds little because the attacker stays within range. Quarantine drives A4 to 2.0%, at the cost of finance completion.

A5 (mass deletion). Caught by the bulk-rate feature when the count is far above the agent's history. Of A5 episodes under ALIZA, 21.1% pass without escalation and only 1.6% are approved directly. The unescalated ones are deletions that no longer stand out because earlier approved deletions raised $D_\alpha^{\max}$; quarantine, which blocks exactly that update, cuts A5 to 2.0%. This is the clearest instance of baseline poisoning by approval in our data.

D. Lessons from calibration

The trust-decay result (Table XVIII) generalizes. When thresholds are quantiles of benign scores, any signal that moves benign and malicious calls together is neutralized by recalibration, and can even hurt by widening the benign tail. Designers of calibrated detectors should judge a feature by how it separates the two populations near the threshold, not by whether it raises attack scores.

E. Deployment guidance

Table XXVI turns the results into recommendations.

F. Threats to validity

Table XXVII summarizes the main threats and what we did about each. The benchmark is synthetic. Tool paths, argument distributions, attacker placement and reviewer behaviour are

Table XXVI
DEPLOYMENT GUIDANCE FROM THE RESULTS

Situation	Recommendation
A crisp rule exists (secrets to unknown hosts, bulk deletion)	Enforce it deterministically in front of ALIZA; learned scoring adds leakage on these classes.
Label-clean misuse (fraud, mimicry)	Use ALIZA's novelty and flow features; expect most catches at step-up.
Reviewers are rushed or untrained	Expect ASR to rise roughly linearly with p_{fool}; show the triggering evidence on the review screen.
Long-running deployment	Monitor ASR proxies over time; use $k_s \geq 3$; add trust expiry.
Payment workflows	Pre-register payees; do not use quarantine without them (15.5% completion).
New workflow onboarding	Pre-register its destinations or raise θ_2 for that workflow during ramp-up.
Review budget	Set ε_s near 3%; beyond it, ASR gains flatten while friction grows.

Table XXVII
THREATS TO VALIDITY

Threat	Mitigation or status
Synthetic workload	Benign traffic includes new contacts, new payees and internal secret use; code released. Not mitigated: no real traces.
Weights hand-set	16 random $\pm 30\%$ perturbations; 15 of 16 still beat rules on ASR.
Test seeds seen in development	Disclosed; sensitivity and grid sweeps support the conclusions.
Single operating point	Full threshold sweeps and a 3×3 calibration grid.
Weak rule baseline	Labelled as a stand-in; layering result shows rules and ALIZA combine.
Small sample of seeds	10 paired seeds, Wilcoxon tests, bootstrap CIs; $\approx$600 attacks per seed.
Reviewer model	p_{fool} swept from 0 to 1.
Non-adaptive attacker	Not mitigated; threshold probing is future work.

modelled, not observed, and the conclusions hold only as far as these models resemble real deployments. We did not run a live LLM; real agents produce longer, noisier tool sequences and may fail in ways our path generator does not. The attacker is adaptive only in choosing in-scope tools and reusing endpoints; it does not probe thresholds. The taint model is episode-level, which inflates flow risk for benign tasks. Finally, our rule baseline is a simple stand-in; production IFC systems encode richer policies and would likely score better than ours on A3.

G. Ethical considerations

This work evaluates defences only, in simulation. The attack classes are generic descriptions already present in public benchmarks [7, 8], and the artefact contains no working exploits against real systems.

IX. CONCLUSION AND FUTURE WORK

ALIZA applies zero-trust per-action authorization to LLM agents with learned, context-aware risk scoring. In a reproducible benchmark it lowers attack success below rule-based and anomaly-based baselines, mainly by catching misuse that is in scope and carries no sensitive label, at the cost of a few human reviews per hundred actions; layered behind deterministic rules it lowers attack success further, to 7.4%. The same learning that makes it usable makes it absorb attacks that reviewers approve, exception decay only slows this trust creep, and quarantine stops it at a steep usability price in payment workflows. Learned agent authorization should be judged by how its trust evolves, not only by its accuracy on day one.

Future work has four parts: validating ALIZA on AgentDojo [8] and InjecAgent [7] traces with a real agent; replacing the coarse taint with value-level provenance in the style of CaMeL and FIDES [14, 15]; adding expiring trust and external systems of record; and evaluating against an adaptive attacker that probes thresholds.

Table XXVIII
PER-SEED ASR / BTC (%), CAMPAIGN REGIME

Seed	RBAC+IFC	Seq. anom.	ALIZA	ALIZA-Q	Layered
0	31.2 / 96.9	60.2 / 97.3	12.1 / 94.6	7.6 / 81.1	8.1 / 92.7
1	29.6 / 97.2	59.5 / 96.7	18.1 / 95.5	9.4 / 81.6	5.8 / 90.7
2	30.1 / 98.1	51.1 / 96.3	18.2 / 95.2	8.2 / 81.5	7.9 / 92.2
3	31.8 / 97.2	58.8 / 95.2	15.1 / 92.8	10.7 / 81.4	8.5 / 91.1
4	33.3 / 95.7	51.5 / 95.0	11.4 / 91.4	8.6 / 80.6	6.6 / 88.1
5	33.6 / 96.9	60.8 / 94.4	20.9 / 94.8	12.1 / 82.6	7.2 / 91.7
6	28.2 / 97.8	48.2 / 94.8	28.7 / 90.6	6.9 / 81.0	3.8 / 87.0
7	30.6 / 97.2	59.5 / 95.6	22.8 / 95.1	15.9 / 81.5	8.3 / 92.2
8	34.0 / 97.6	53.8 / 92.0	26.0 / 93.9	11.3 / 80.4	12.1 / 88.0
9	30.6 / 96.4	57.9 / 93.5	16.5 / 94.4	8.3 / 80.4	6.2 / 86.0

Table XXIX
MEAN WEIGHTED FEATURE CONTRIBUTION

Calls	n	seq	flow	nov	amt	rate	sum
Benign	97,109	0.10	0.09	0.04	0.02	0.00	0.25
A1 goal	408	0.27	0.90	0.69	0.00	0.00	1.85
A3 goal	1181	0.06	0.82	0.84	0.00	0.00	1.72
A4 goal	1070	0.21	1.10	0.97	0.28	0.00	2.56
A5 goal	1238	0.29	0.00	0.00	0.00	1.98	2.27

APPENDIX A: PER-SEED RESULTS

Table XXVIII lists each test seed's ASR and BTC (campaign regime), the data behind Table XIII. Seed 6 is the only one where ALIZA does not beat the rule baseline on ASR (28.7% versus 28.2%).

APPENDIX B: FEATURE VALUES BY ATTACK CLASS

Table XXIX gives the numbers behind Fig. 13: mean weighted contribution $\gamma(c_t)w_k f_k$ of each feature for benign calls and for each class's in-scope goal calls. A1's in-scope goal calls come only from the devops carrier (408 of 1188 episodes); A2 has none.

APPENDIX C: DERIVATION OF THE REVIEW COUNT

Under Assumption 1, each benign call is escalated with probability ρ_s, so an episode of n benign calls that is not cut short produces $\text{Bin}(n, \rho_s)$ step-ups. Escalations end the episode with probability $1 - 0.97$ each, so the expected number of reviews per benign episode is at most $n\rho_s$; with $n = \bar{n} = 4.05$ and $\rho_s = 0.03$ this is 0.12, or about one review every eight benign episodes. The measured value is $4.05 \times 0.0358 = 0.145$, one

Table XXX
FEATURE CONSTANTS AND RATIONALE

Constant	Value	Rationale
f_{seq} divisor	6	maps a 1-in-400 transition ($-\ln \hat{P} \approx 6$) to 1.0
f_{seq} cap	1.5	one rare transition alone cannot reach θ_2
f_{flow} coefficients	.25/.25/.5	sensitivity ≥ 2 counts double untrusted context
f_{amt} divisor	$3(\sigma + 0.2)$	3-sigma deviation maps to 1.0; 0.2 floors σ for short histories
f_{amt} cold start	0.5	fewer than 3 samples: moderate suspicion
f_{amt} cap	1.5	amount alone cannot reach θ_2
$D_{\alpha}^{\max}$ initial	3	matches the benign 1–3 file range
f_{rate} divisor	1.5	tenfold excess maps to $\approx$1.5
f_{rate} cap	3	hundredfold excess alone denies
smoothing β	0.1	unseen transitions stay rare but finite

every seven, because realized friction (3.58%) exceeds the target, as allowed by Theorem 1.

APPENDIX D: FEATURE CONSTANTS

Table XXX lists every constant inside the feature definitions and the reason for its value. All were fixed before the first test run.

REPRODUCIBILITY

`aliza_sim.py` runs the core experiments (about two minutes on two vCPUs) and writes `results.json`; `aliza_extra.py` runs the extended experiments (about 90 seconds) and writes `results_extra.json`; `trace.py` extracts the worked example; `make_figs.py` and `make_figs_extra.py` draw every figure from those files. An instrumented runner used for the extended experiments reproduces the core runner's results exactly on seed 0 (ASR 12.12%, BTC 94.64% in both). Seeds: calibration 1001–1003, development 500–502, test 0–9.

REFERENCES

[1] S. Yao, J. Zhao, D. Yu, N. Du, I. Shafran, K. Narasimhan, and Y. Cao, "ReAct: Synergizing reasoning and acting in language models," in *Proc. ICLR*, 2023.

[2] T. Schick, J. Dwivedi-Yu, R. Dessì, R. Raileanu, M. Lomeli, E. Hambro, L. Zettlemoyer, N. Cancedda, and T. Scialom, "Toolformer: Language models can teach themselves to use tools," in *Proc. NeurIPS*, 2023.

[3] Anthropic, "Introducing the Model Context Protocol," Nov. 2024. [Online]. Available: https://www.anthropic.com/news/model-context-protocol

[4] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proc. ACM AISec Workshop*, 2023.

[5] F. Perez and I. Ribeiro, "Ignore previous prompt: Attack techniques for language models," arXiv:2211.09527, 2022.

[6] Y. Liu, Y. Jia, R. Geng, J. Jia, and N. Z. Gong, "Formalizing and benchmarking prompt injection attacks and defenses," in *Proc. USENIX Security Symp.*, 2024.

[7] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, "InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents," in *Findings of ACL*, 2024.

[8] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents," in *Proc. NeurIPS Datasets and Benchmarks Track*, 2024.

[9] OWASP Foundation, "OWASP Top 10 for LLM Applications 2025," 2024.

[10] E. Wallace, K. Xiao, R. Leike, L. Weng, J. Heidecke, and A. Beutel, "The instruction hierarchy: Training LLMs to prioritize privileged instructions," arXiv:2404.13208, 2024.

[11] K. Hines, G. Lopez, M. Hall, F. Zarfati, Y. Zunger, and E. Kiciman, "Defending against indirect prompt injection attacks with spotlighting," arXiv:2403.14720, 2024.

[12] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, "StruQ: Defending against prompt injection with structured queries," in *Proc. USENIX Security Symp.*, 2025.

[13] T. Shi, J. He, Z. Wang, L. Wu, H. Li, W. Guo, and D. Song, "Progent: Programmable privilege control for LLM agents," arXiv:2504.11703, 2025.

[14] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr, "Defeating prompt injections by design," arXiv:2503.18813, 2025.

[15] M. Costa, B. Köpf, A. Kolluri, A. Paverd, M. Russinovich, A. Salem, S. Tople, L. Wutschitz, and S. Zanella-Béguelin, "Securing AI agents with information-flow control," arXiv:2505.23643, 2025.

[16] Y. Wu, F. Roesner, T. Kohno, N. Zhang, and U. Iqbal, "IsolateGPT: An execution isolation architecture for LLM-based agentic systems," in *Proc. NDSS*, 2025.

[17] N. Hardy, "The confused deputy (or why capabilities might have been invented)," *ACM SIGOPS Oper. Syst. Rev.*, vol. 22, no. 4, pp. 36–38, 1988.

[18] J. H. Saltzer and M. D. Schroeder, "The protection of information in computer systems," *Proc. IEEE*, vol. 63, no. 9, pp. 1278–1308, 1975.

[19] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," NIST Special Publication 800-207, Aug. 2020.

[20] J. Kindervag, "No more chewy centers: Introducing the zero trust model of information security," Forrester Research, 2010.

[21] B. Biggio and F. Roli, "Wild patterns: Ten years after the rise of adversarial machine learning," *Pattern Recognition*, vol. 84, pp. 317–331, 2018.

[22] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in *Proc. IEEE Symp. Security and Privacy*, 2010, pp. 305–316.

[23] Y. Ruan, H. Dong, A. Wang, S. Pitis, Y. Zhou, J. Ba, Y. Dubois, C. J. Maddison, and T. Hashimoto, "Identifying the risks of LM agents with an LM-emulated sandbox," in *Proc. ICLR*, 2024.

[24] S. Forrest, S. A. Hofmeyr, A. Somayaji, and T. A. Longstaff, "A sense of self for Unix processes," in *Proc. IEEE Symp. Security and Privacy*, 1996, pp. 120–128.

[25] V. Chandola, A. Banerjee, and V. Kumar, "Anomaly detection: A survey," *ACM Comput. Surv.*, vol. 41, no. 3, art. 15, 2009.

[26] J. Gama, I. Žliobaitė, A. Bifet, M. Pechenizkiy, and A. Bouchachia, "A survey on concept drift adaptation," *ACM Comput. Surv.*, vol. 46, no. 4, art. 44, 2014.

[27] R. Parasuraman and V. Riley, "Humans and automation: Use, misuse, disuse, abuse," *Human Factors*, vol. 39, no. 2, pp. 230–253, 1997.

[28] A. Dvoretzky, J. Kiefer, and J. Wolfowitz, "Asymptotic minimax character of the sample distribution function and of the classical multinomial estimator," *Ann. Math. Statist.*, vol. 27, no. 3, pp. 642–669, 1956.

[29] P. Massart, "The tight constant in the Dvoretzky–Kiefer–Wolfowitz inequality," *Ann. Probab.*, vol. 18, no. 3, pp. 1269–1283, 1990.

[30] F. Wilcoxon, "Individual comparisons by ranking methods," *Biometrics Bulletin*, vol. 1, no. 6, pp. 80–83, 1945.

[31] B. Efron, "Bootstrap methods: Another look at the jackknife," *Ann. Statist.*, vol. 7, no. 1, pp. 1–26, 1979.